

Plan de respuesta a incidentes para CyberConsulting SL

Autor: Grupo 2, contact@cyberconsulting.com

Revisión 0.1, Publicado 18-05-2026

Abstract

Este plan de respuesta a incidentes está basado en el plan conciso, directivo, específico, flexible y gratuito disponible Github de Counteractive Security's y discutido en www.counteractive.net

Fue revisado por última vez el 18-05-2026. Fue probado por última vez en 18-05-2026.

Contents

Plan de respuesta a incidentes para CyberConsulting SL	5
Propósito y alcance (CyberConsulting)	5
Evaluar	6
Evaluar el impacto funcional	6
Evaluar el impacto de la información	6
Clasificación rápida de severidad	6
Iniciar la respuesta	7
Nombrar el incidente	7
Reunir el equipo de respuesta	7
Referencia: Estructura del equipo de respuesta	8
Referencia: Información de contacto del equipo de respuesta	8
Establecer el ritmo de batalla	9
Realizar la primera llamada de respuesta	9
Realizar la actualización de la respuesta	10
Supervisar el alcance	11
Crear Sub-Equipos	11
Incidente dividido	12
Investigar	12
Crear el archivo del incidente	12
Recoger las pistas iniciales	13
Referencia: Lista de recursos de respuesta	13

Actualizar el plan de investigación y el archivo del incidente	14
Referencia: Táctica del atacante a la matriz de preguntas clave .	15
Crear y desplegar indicadores de compromiso (IOC)	16
Identificar los sistemas de interés	16
Recogida de pruebas	16
Ejemplo de artefactos útiles	17
Analizar las pruebas	18
Ejemplo de indicadores útiles	18
Iterar la investigación	19
Remediar	19
Actualización del plan de remediación	19
Protección	19
Detección	20
Contención	20
Erradicar	21
Elegir el momento de la reparación	21
Ejecutar la remediación	21
Iterar la remediación	22
Comunicar	22
Comunicación Interna	22
Notificar y actualizar a las partes interesadas	22
Notificar y actualizar la organización	22
Crear Informe de Incidentes	23
Comunicar al exterior	23
Notificar a los reguladores	23
Notificar a los clientes	23
Notificar a los proveedores y socios	24
Notificar a las Fuerzas de Seguridad	24
Contactar con el servicio de asistencia de respuesta externa . . .	24
Compartir Inteligencia	24
Recuperación	25
Cierre del incidente	25
Playbooks	25
Playbook: Phishing	26
Diagrama de Flujo del Proceso	26
Investigar	27
Remediar	30
Comunicar	31
Recuperación	32
Recursos	33
Técnicas MITRE ATT&CK Relevantes en Este Playbook	35

Cadena de Ataque: Visualización Completa	35
Playbook: Ransomware	38
Diagrama de Flujo del Proceso	39
Investigar	39
Remediar	41
Comunicar	42
Recuperación	43
Técnicas MITRE ATT&CK Relevantes en Este Playbook	43
Cadena de Ataque: Visualización Completa	43
Recursos	45
Playbook: Compromiso de la cadena de suministro	45
Diagrama de Flujo del Proceso	46
Investigar	47
Remediar	48
Comunicar	50
Recuperación	51
Técnicas MITRE ATT&CK Relevantes en Este Playbook	52
Cadena de Ataque: Visualización Completa	52
Recursos	54
Playbook: Acceso No Autorizado	54
Cadena de Ataque	54
Investigar	54
Remediar	57
Comunicar	59
Recuperación	59
Referencia: Acciones del usuario ante la sospecha de acceso no autorizado a su cuenta	60
Referencia: Acciones del servicio de asistencia técnica ante la sospecha de acceso no autorizado	61
Recursos	61
Diagrama de Flujo del Incidente	63
1. Investigar	64
Los Primeros 15–30 Minutos (Acciones Inmediatas)	64
Entendiendo Qué Fue Comprometido	64
Buscando el Punto de Entrada	65
La Gravedad del Incidente	65
2. Remediar: Contener, Erradicar y Recuperar	66
Contención: Frenar la Salida de Datos	66
Erradicación: Limpiar el Entorno	66
Recuperación: Volver a Poner Todo en Marcha	67
3. Comunicar	68
Los Primeros 72 Horas: La Notificación Regulatoria	68
Eleva a Dirección: El Comité de Crisis	68
Comunicación a Clientes Afectados	69
Coordinación con el Proveedor Externo	69
4. Recuperación y Lecciones Aprendidas	70

Restauración del Servicio	70
Medidas de Seguridad a Largo Plazo	70
Lecciones Aprendidas	71
Recordatorios Prácticos	71
Técnicas MITRE ATT&CK Relevantes en Este Playbook	72
Cadena de Ataque: Visualización Completa	72
Visualización Interactiva con React	74
alt text	74
Recursos y Referencias	74
Cadena de Ataque	74
Investigar	75
Remediar	76
Comunicar	78
Recuperación	79
Referencia: Acciones del empleado ante la pérdida o robo de un dispositivo corporativo	80
Referencia: Acciones del servicio de asistencia técnica ante la notificación de pérdida o robo de dispositivo	80
Recursos	81
Estructura de los roles	81
Tiempos de Guerra vs. Tiempos de Paz	82
Roles: Todos los participantes	82
Descripción	82
Deberes	83
Capacitación	84
Descripción	84
Deberes	84
Prácticas	85
Rol: adjunto del Incident Commander (adjunto)	86
Descripción	86
Funciones	86
Formación	87
Rol: Escriba	87
Descripción	87
Funciones	87
Formación	88
Rol: Experto en la materia {Subject Matter Expert (SME)}	88
Descripción	88
Funciones	88
Formación	89
Rol: Enlace	89
Descripción	89
Deberes	90
Formación	91

Realizar una revisión posterior a la acción (Conduct an After

Action Review, AAR)	91
Realización de la reunión AAR	91
Comunicar el estado y los resultados del AAR	92
Descripciones de estado	92
Acerca de	92
Licencia	93
Instrucciones	93
Referencias y material adicional	93

Plan de respuesta a incidentes para CyberConsulting SL

Autor: Grupo 2, contact@cyberconsulting.com

Revisión 0.1, Publicado 18-05-2026

Este plan de respuesta a incidentes está basado en el plan conciso, directivo, específico, flexible y gratuito disponible en Github de Counteractive Security y discutido en www.counteractive.net

Fue revisado por última vez el 18-05-2026. Fue probado por última vez en 18-05-2026.

Propósito y alcance (CyberConsulting)

Este plan define **cómo evaluamos, activamos, coordinamos y ejecutamos** la respuesta ante incidentes de ciberseguridad que puedan afectar a:

- Operación interna (puestos, servidores locales, red de las sedes, identidades y correo)
- Servicios cloud y SaaS
- La web/tienda online externalizada
- Proveedores críticos y relaciones de confianza
- Dispositivos corporativos (portátiles/móviles) en caso de pérdida/robo

Principios:

- **Contener primero** cuando haya riesgo de propagación o impacto alto; investigar en paralelo.
- **Registrar decisiones y evidencias desde el minuto 0** (línea de tiempo, acciones, responsables).
- **Comunicar con hechos**, no con especulaciones, y por los canales definidos.

Este plan se complementa con los playbooks anexos (Phishing, Ransomware, Supply Chain, Exfiltración web, Acceso no autorizado y Pérdida/robo de dispositivo).

Evaluar

1. **Mantenga la calma y la profesionalidad.**
2. Reúna la información pertinente, *por ejemplo*, alarmas, eventos, datos, suposiciones, intuiciones (**observar**).
3. Considerar las categorías de impacto, a continuación (**orientar**), y determinar si hay un posible incidente (**decidir**):
4. Iniciar una respuesta si hay un incidente (**actuar**). En caso de duda, inicie una respuesta. El responsable de gestión de incidentes y el equipo de respuesta pueden ajustarse tras la investigación y la revisión.

Evaluar el impacto funcional

¿Cuál es el impacto directo o probable en su trabajo? (*por ejemplo*, operaciones comerciales, empleados, clientes, usuarios)

- Degradación o fracaso del trabajo/negocio: **incidente!**
- Ninguno: evalúe el impacto de la información.

Evaluar el impacto de la información

¿Cuál es el impacto directo o probable sobre sus datos/información, en particular los sensibles? (*por ejemplo*, información personal, datos de propiedad, financieros o sanitarios)

- Información a la que se ha accedido, cogido, cambiado o borrado: **incidente!**
- Ninguno: gestión a través de canales no relacionados con incidentes (por ejemplo, un ticket de soporte).

Cada miembro del equipo está facultado para comenzar este proceso.
Si ves algo, dilo.

Clasificación rápida de severidad

Use esta clasificación para priorizar y decidir escalado. Si hay duda, clasifique más alto y ajuste después.

Severidad	Criterio (resumen)	Ejemplos típicos
SEV-1 (Crítico)	Parada del negocio, cifrado activo, exfiltración confirmada de datos sensibles, o compromiso de cuentas privilegiadas con impacto amplio	Ransomware en servidores/shares; exfiltración RGPD; takeover de admin/tenant; compromiso proveedor con alcance operativo

Severidad	Criterio (resumen)	Ejemplos típicos
SEV-2 (Alto)	Compromiso probable/confirmado limitado pero con riesgo de escalar	Phishing con credenciales usadas; acceso no autorizado a un equipo; malware contenido en un endpoint
SEV-3 (Medio/Bajo)	Incidente menor o intento bloqueado con bajo impacto	Phishing bloqueado por gateway; escaneo sin explotación; dispositivo perdido sin señales de acceso

El Incident Commander puede ajustar severidad durante la investigación.

Iniciar la respuesta

Nombrar el incidente

Utilice un nombre corto y único para el incidente (para canal, llamada y carpeta de evidencias). Formato recomendado:

- INC-YYYYMMDD-<CODENAME> (ej.: INC-20260519-PINO-ROJO)

Reglas:

- No usar nombres de clientes/personas.
- Mantenerlo estable (no renombrar a mitad de incidente salvo colisión).

Reunir el equipo de respuesta

1. Llame al Incident Commander de turno/de guardia (ver <https://wiki.cyberconsulting.com/ir/rosters/incident-commander>). Si no responde, escale al siguiente IC en la lista.
2. **No** discuta el incidente fuera del equipo de respuesta a menos que el Incident Commander lo autorice
3. Inicie y/o únase al chat de respuesta en Microsoft Teams: Equipo "IR" / Canal "incidentes".
4. Iniciar y/o unirse a la llamada de respuesta en +34 600 000 000 y/o [zoom.com/cyberconsulting](https://zoom.com/join/9123456789).
5. Preferible usar la llamada de voz, el chat y el intercambio seguro de archivos sobre cualquier otro método.
6. **No** utilizar el correo electrónico principal si es posible. Si el correo electrónico es necesario, utilícelo con moderación o use ir@cyberconsulting.com. Encripte los correos electrónicos cuando cualquier participante esté fuera del dominio cyberconsulting.com.

7. **No** usar SMS/texto para comunicar el incidente, a menos que sea para decirle a alguien que se mueva a un canal más seguro.
8. Invite al personal de turno/guardia a la llamada y al chat de respuesta.
 - Invite al equipo de seguridad (ver <https://wiki.cyberconsulting.com/ir/rosters/security-team>).
 - Invitar al SME de los equipos y sistemas afectados (ver <https://wiki.cyberconsulting.com/ir/rosters/sme>).
 - Invitar a las partes interesadas ejecutivas y a los asesores jurídicos lo antes posible (ver <https://wiki.cyberconsulting.com/ir/rosters/executive>), priorizando primero la estabilización técnica.
9. OPCIONAL: Establecer una sala de colaboración en persona (“sala de guerra”) para incidentes SEV-1/SEV-2.

Referencia: Estructura del equipo de respuesta

- Equipo de Mando
 - Incident Commander
 - Incident Commander-Adjunto
 - Escriba
- Equipo de enlace
 - Enlace interno
 - Enlace externo
- Equipo de operaciones
 - Expertos en la materia (SME) para sistemas
 - SME para equipos/unidades de negocio
 - SME para Funciones Ejecutivas (*por ejemplo*, Legal, RRHH, Finanzas)

La estructura de roles es flexible y se ajusta a la severidad del incidente.

Referencia: Información de contacto del equipo de respuesta

Rol del equipo de respuesta	Información de contacto
Localizador del Incident Commander	+34 900 123 456 (guardia) / Ext. 777
Url del Incident Commander	https://oncall.cyberconsulting.com/ic
Lista del Incident Commander	https://wiki.cyberconsulting.com/ir/rosters/incident-commander
Lista del equipo de seguridad	https://wiki.cyberconsulting.com/ir/rosters/security-team
Lista del equipo SME	https://wiki.cyberconsulting.com/ir/rosters/sme
Lista de ejecutivos	https://wiki.cyberconsulting.com/ir/rosters/executive

Las listas anteriores deben incluir también el **procedimiento de contacto** (turnos/guardias, escalado y sustituciones) para evitar bloqueos.

Establecer el ritmo de batalla

Realizar la primera llamada de respuesta

1. Realice la llamada inicial utilizando la estructura de llamada de respuesta inicial
2. Siga las instrucciones del Incident Commander. Si el Incident Commander de turno/de guardia no se une a la llamada **dentro de 15 minutos** y usted es un Incident Commander capacitado, tome el mando de la llamada.
3. Siga las instrucciones correspondientes a su función.
4. Siga la llamada y el chat, y comente según corresponda. Si no es un SME, comunique las aportaciones a través del SME de su equipo si es posible.
5. **Mantenga la llamada y el chat activos durante todo el incidente para una comunicación basada en eventos.**
6. Programe actualizaciones **cada 4 horas (SEV-1: 1 hora)** sobre la comunicación activa.

Referencia: Estructura de la llamada de respuesta inicial

- Incident Commander (IC): Mi nombre es [NOMBRE], soy el Incident Commander. He designado a [NOMBRE] como adjunto y a [NOMBRE] como escriba. ¿Quién está en la llamada?
- ESCRIBA: [Toma asistencia]
- IC: [Si falta personal clave] Adjunto, por favor llame a [PERSONAL FALTANTE].
- IC: [Hace preguntas para comprender la situación, los síntomas, el alcance, el vector, el impacto y el calendario del reportador del incidente, los SME aplicables para los sistemas y las unidades de negocio].
- SMEs: [Responde brevemente a las preguntas del IC].
- IC: [Si se trata de un incidente]:
 - En este momento, el resumen del incidente es el siguiente: [reitera el resumen]. El equipo de investigación estará dirigido por [NOMBRE], el equipo de reparación estará dirigido por [NOMBRE] y el equipo de comunicación estará dirigido por [NOMBRE]. Ellos coordinarán la composición del equipo y me informarán. Los miembros del equipo, por favor, informen a su jefe de equipo correspondiente.
 - ¿Qué medidas de investigación, corrección o comunicación se han tomado ya? [esta debería ser una lista corta, pero tiene que salir ahora]
 - Esta llamada y el chat permanecerán activos y disponibles hasta el cierre del incidente, por favor, utilícelos para todas las comunicaciones relacionadas con el incidente. Proporcione actualizaciones de estado en tiempo real en el chat, si es posible. ¿Hay alguna pregunta o aportación restante? [responde a las preguntas]
 - Líderes de equipo, por favor procedan con sus acciones planeadas. Nos reuniremos de nuevo en [UPDATE_TIME] para discutir el estado. Gracias.

- IC: [Si esto no es un incidente]: En este momento, estos hechos no alcanzan el nivel de un incidente. Me coordinaré directamente con el reportador del incidente para las acciones de seguimiento. Gracias por su tiempo.

Referencia: Etiqueta de la llamada

- Únase tanto a la llamada como al chat.
- Mantenga el ruido de fondo al mínimo.
- Mantenga su micrófono silenciado hasta que tenga algo que decir.
- Identifícate cuando te unas a la llamada; di tu nombre y tu función (por ejemplo, “Soy el SME del equipo x”).
- Habla con claridad.
- Sea directo y objetivo.
- Mantenga conversaciones/discusiones cortas y al grano.
- Comunicar cualquier preocupación al Incident Commander (CI) en la llamada.
- Respetar las limitaciones de tiempo impuestas por el Incident Commander.
- **Utilizar una terminología clara y evitar acrónimos o abreviaturas. La claridad y la precisión son más importantes que la brevedad.

Realizar la actualización de la respuesta

- Llevar a cabo actualizaciones programadas utilizando la estructura de llamada de actualización cada 4 horas (SEV-1: 1 hora) en el puente activo.
- Ajustar la frecuencia según sea necesario.
- Coordinar las actualizaciones independientes (*por ejemplo*, ejecutivas, legales) según sea necesario, pero con la menor frecuencia posible.

Guía práctica:

- **SEV-1:** actualizaciones frecuentes y por evento (cambios de contención, caída/recuperación de servicios, hallazgos críticos).
- **SEV-2/3:** mantener un ritmo que no bloquee la ejecución (menos reuniones, más trabajo).

Referencia: Estructura de la llamada de actualización de la respuesta

- Incident Commander (IC): Desde la última actualización programada, el resumen del incidente es el siguiente:
 - [Impacto]
 - [Vector]
 - [Actualización del resumen]
 - [Actualización de la línea de tiempo]
- IC: Equipo de investigación, por favor proporcione una breve actualización
 - LÍDER DE LA INVESTIGACIÓN: [Actividades de investigación o “nada que informar”]
 - ¿Cuál es su plan de investigación recomendado?

- ¿Qué acciones de investigación necesitan ser asignadas o aprobadas? [escuchar, obtener consenso, encargar/aprobar]
- IC: Equipo de remediación, por favor proporcione una breve actualización
 - Líder de remediación: [Actividades de remediación o “nada que informar”]
 - ¿Cuál es su estrategia de corrección recomendada? ¿Objeciones fuertes? [escuchar, obtener el consenso, asignar/aprobar]
 - ¿Qué acciones de corrección necesitan ser asignadas o aprobadas?
- IC: Equipo de comunicación, por favor, proporcione una breve actualización:
 - COMMUNICATIONS LEAD: [Actividades de comunicación o “nada que informar”]
 - ¿Cuál es su estrategia de comunicación recomendada? ¿Objeciones fuertes? [escuchar, obtener consenso, encargar/aprobar]
 - ¿Qué acciones de comunicación necesitan ser asignadas o aprobadas?
- IC: Esta llamada y el chat permanecerán activos y disponibles hasta el cierre del incidente, por favor, utilícelos para todas las comunicaciones relacionadas con el incidente. Si es posible, proporcione actualizaciones del estado en tiempo real en el chat. ¿Hay alguna pregunta o aportación restante? [responde a las preguntas]
- IC: Líderes de equipo, por favor procedan. Nos reuniremos de nuevo en [] para discutir el estado. Gracias.

Supervisar el alcance

- Supervisar el alcance de la respuesta para asegurarse de que no excede el ámbito de control del Incident Commander.
- Si un incidente es lo suficientemente complejo y hay suficientes intervinientes, considere la posibilidad de crear subequipos.

Crear Sub-Equipos

- Para incidentes SEV-1/SEV-2, se predefinen tres subequipos: **Investigación, Remediación y Comunicación.**
- Crear un puente de llamadas y un chat para cada subequipo.
- El Incident Commander designará a los líderes de los equipos, que dependen del IC, y a los miembros de los equipos, que dependen de su líder. *Los líderes de equipo no tienen que estar formados como Incident Commanders, pero es preferible que tengan alguna experiencia de liderazgo.*
- El Incident Commander puede ajustar el propósito o el nombre de los subequipos según sea necesario.
- Si desea cambiar de equipo, pregunte a su **líder de equipo actual**. No pregunte al Incident Commander, o al líder del otro(s) equipo(s). Utilice la cadena de mando.

Incidente dividido

Si un incidente resulta ser dos o más incidentes distintos:

- Establezca un nuevo archivo de incidentes.
- Haga un seguimiento y coordine la investigación, la reparación y la comunicación en el archivo correspondiente.
- Considere la posibilidad de establecer subequipos para cada incidente.
- **Mantener un Incident Commander de alto nivel**, para coordinar los activos de baja densidad y alta demanda y mantener la unidad de mando.

Investigar

Investigar, Remediar y comunicar en paralelo, utilizando equipos separados, si es posible. El Incident Commander coordinará estas actividades. Notifique al Incident Commander si hay pasos que el equipo debe considerar.

Crear el archivo del incidente

1. Cree un nuevo archivo de incidentes en <https://share.cyberconsulting.com/sites/IR/Incidents/<INC-CODENAME>> utilizando el nombre del incidente. Utilice este archivo para el almacenamiento seguro de documentación, pruebas, artefactos, *etc.*.
 - Proporcionar un almacenamiento digital seguro.
 - Proporcionar un intercambio de archivos seguro.
 - Obtener almacenamiento físico.
 - Compartir la ubicación del archivo del incidente en la llamada y el chat.
- Establecer un documento de “línea de tiempo” y un registro de decisiones (quién decidió qué y cuándo).
1. Documente el impacto funcional y de la información, si se conoce (véase Evaluar).
2. Documentar el vector, si se conoce (*por ejemplo* web, correo electrónico, medios extraíbles). Vectores típicos: **correo/phishing, SaaS/Identidad, web/tienda externalizada, endpoint, proveedor/supply chain, pérdida/robo de dispositivo, acceso físico/lógico.**
3. Documente el resumen del incidente: un breve resumen del vector, el impacto, la investigación y la situación de la reparación, si se conoce.
4. Documente la línea de tiempo del incidente, incluyendo la actividad del atacante y la actividad de la respuesta.
5. Documente los pasos de investigación, reparación y comunicación. Documente las actividades de forma independiente para que puedan combinarse y reutilizarse, si es posible.
6. Registre la información significativa, como: **Pruebas**, con la hora de recogida, la fuente, la cadena de custodia, *etc.*

- **Sistemas afectados**, con el modo y el momento en que se identificó el sistema, y el resumen del efecto (_por ejemplo, tiene malware, datos a los que se ha accedido).
- **Archivos de interés**, como el malware o los archivos de datos, con el sistema y los metadatos.
- **Datos accedidos y tomados**, con nombres de archivos, metadatos y hora de presunta exposición.
- **Actividad significativa del atacante**, como inicios de sesión y ejecución de malware, con la hora del evento.
- **Indicadores de compromiso (IOC)** basados en la red, como direcciones IP y dominios.
- **Indicadores de compromiso basados en el host**, como nombres de archivos, hashes y claves de registro.
- **Cuentas comprometidas**, con el alcance del acceso y la hora del compromiso.

Procedimiento mínimo de documentación (obligatorio):

- Un ticket/caso principal (ITSM) con severidad, estado y responsables.
- Línea de tiempo con timestamps (UTC o hora local consistente).
- Registro de acciones de contención/erradicación con responsable y resultado.
- Evidencias adjuntas o referenciadas (logs, capturas, correos .eml/.msg, hashes).

Recoger las pistas iniciales

1. Entrevistar a los reportadores del incidente.
2. Recoger los datos de apoyo iniciales (e., alarmas, eventos, datos, suposiciones, intuiciones) en el archivo del incidente.
3. Entrevistar a lo(s) SME con experiencia en el dominio o el sistema, para comprender los detalles técnicos, el contexto y el riesgo.
4. Entrevistar a lo(s) SME de la unidad de negocio afectada, para comprender el impacto de la misión/negocio, el contexto y el riesgo.
5. Asegúrese de que las pistas son relevantes, detalladas y procesables.

Referencia: Lista de recursos de respuesta

Recurso	Ubicación
Lista de información crítica	https://share.cyberconsulting.com/sites/IR/Lists/Critical-Info
Lista de activos críticos	https://share.cyberconsulting.com/sites/IR/Lists/Critical-Assets
Base de datos de gestión de activos	https://cmdb.cyberconsulting.com

Recurso	Ubicación
Mapa de red	https://wiki.cyberconsulting.com/it/network-map
Consola SIEM	Microsoft Sentinel (Azure Portal)
Agregador de registros	https://logs.cyberconsulting.com (Kibana)

Complete y mantenga actualizadas las listas de información y activos críticos (“joyas de la corona”). Esto es clave para una respuesta eficaz.

Ajuste esta lista de recursos para reflejar herramientas reales (SIEM/EDR/IdP/correo/web/tienda/proveedores) y cómo acceder a ellas.

Actualizar el plan de investigación y el archivo del incidente

1. Revisar y perfeccionar el impacto del incidente.
2. Revisar y refinar el vector del incidente.
3. Revisar y perfeccionar el resumen del incidente.
4. Revisar y perfeccionar la línea de tiempo del incidente con hechos e inferencias.
5. Crear hipótesis: qué puede haber ocurrido y con qué seguridad.
6. **Identificar y priorizar las preguntas clave** (lagunas de información) para apoyar o desacreditar las hipótesis.
 - Utilizar la matriz ATT&CK de MITRE o un marco similar para desarrollar preguntas.
 - ATT&CK for Enterprise, incluyendo enlaces a los específicos de Windows, Mac y Linux.
 - ATT&CK Mobile Profile para dispositivos móviles.
 - Utilizar palabras interrogativas como inspiración:
 - **¿Cuándo?:** primer compromiso, primera pérdida de datos, acceso a x datos, acceso a y sistema, etc.
 - **¿Qué?:** impacto, vector, causa de origen, motivación, herramientas/explotaciones utilizadas, cuentas/sistemas comprometidos, datos atacados/perdidos, infraestructura, COIs, etc.?
 - **¿Dónde?:** ubicación del atacante, unidades de negocio afectadas, infraestructura, etc.?
 - **¿Cómo?:** compromiso (explotación), persistencia, acceso, exfiltración, movimiento lateral, etc.?
 - **¿Por qué?:** objetivo, momento, acceso a x datos, acceso a y sistema, etc.
 - **¿Quién?:** atacante, usuarios afectados, clientes afectados, etc.?
7. **Identificar y priorizar los dispositivos y estrategias testigo** para responder a las preguntas clave.
 - Consultar los diagramas de la red, los sistemas de gestión de activos y la experiencia de las SME

- Consultar la Lista de recursos de respuesta)
8. Consulte los playbook de incidentes para conocer las preguntas clave, los dispositivos testigos y las estrategias para investigar las amenazas comunes o muy dañinas.

El plan de investigación es fundamental para una respuesta eficaz; impulsa todas las acciones de investigación. Utilice el pensamiento crítico, la creatividad y el buen juicio.

Referencia: Táctica del atacante a la matriz de preguntas clave

Táctica del atacante	La forma en que los atacantes ...	Posibles preguntas clave
Reconocimiento	... aprender sobre los objetivos	¿Cómo? ¿Desde cuándo? ¿Dónde? ¿Qué sistemas?
Desarrollo de recursos	... construir infraestructuras.	¿Qué sistemas?
Acceso inicial	... entrar	¿Cómo? ¿Desde cuándo? ¿Dónde? ¿Qué sistemas?
Ejecución	... ejecutar código hostil	¿Qué malware? ¿Qué herramientas? ¿Dónde? ¿Cuándo?
Persistencia	... quedarse en el sistema	¿Cómo? ¿Desde cuándo? ¿Dónde? ¿Qué sistemas?
Escalada de Privilegios	... obtener acceso de mayor nivel	¿Cómo? ¿Dónde? ¿Qué herramientas?
Evasión de la defensa	... esquivar la seguridad	¿Cómo? ¿Dónde? ¿Desde cuándo?
Acceso a credenciales	... obtener/crear cuentas	¿Qué cuentas? ¿Desde cuándo? ¿Por qué?
Descubrimiento	... aprender nuestra red	¿Cómo? ¿Dónde? ¿Qué saben?
Movimiento lateral	... moverse	¿Cómo? ¿Cuándo? ¿Qué cuentas?
Recogida	... encontrar y reunir datos	¿Qué datos? ¿Por qué? ¿Cuándo? ¿Dónde?
Mando y control	... herramientas y sistemas de control	¿Cómo? ¿Dónde? ¿Quién? ¿Por qué?
Exfiltración	... tomar datos	¿Qué datos? ¿Cómo? ¿Cuándo? ¿Dónde?
Impacto	... romper cosas.	¿Qué sistemas o datos? ¿Cómo? ¿Cuándo? ¿Dónde? ¿Cómo de malo?

Consulte la página MITRE ATT&CK para obtener más información e ideas.

Crear y desplegar indicadores de compromiso (IOC)

Haga hincapié en los indicadores **dinámicos y de comportamiento** junto con las huellas digitales estáticas.

- Crear IOCs basados en pistas iniciales y análisis.
- Cree IOCs usando un formato abierto soportado por sus herramientas (*por ejemplo*, STIX 2.x) o, si es necesario, CSV/JSON simple (dominio, URL, IP, hash, regla) con fecha de alta y caducidad.
- Utilice la automatización cuando sea posible (bloqueo en gateway de correo, proxy/DNS, EDR, firewall) y defina siempre un criterio de retirada (expira/false positive/ya mitigado).
- **No** desplegar “feeds” de IOCs no relacionados y no curados, ya que pueden causar confusión y fatiga.
- Considerar todos los tipos de IOC:
 - IOC basados en la red, como direcciones IP o MAC, puertos, direcciones de correo electrónico, contenido o metadatos del correo electrónico, URLs, dominios o patrones PCAP.
 - IOC basados en el host, como rutas, hashes de archivos, contenido o metadatos de archivos, claves de registro, MUTEXes, autoejecuciones o artefactos y permisos de usuarios.
 - IOCs basados en la nube, como patrones de registro para despliegues SaaS o IaaS
 - IOCs de comportamiento (a.k.a., patrones, TTPs) tales como patrones de árbol de procesos, heurística, desviación de la línea base y patrones de inicio de sesión.
- Correlacionar varios tipos de IOC, como indicadores basados en la red y en el host en los mismos sistemas.

Identificar los sistemas de interés

1. Validar si son relevantes.
2. Categorizar la(s) razón(es) por la(s) que son “de interés”: tiene malware, acceso por cuenta comprometida, tiene datos sensibles, etc. Trátelas como “etiquetas”, puede haber más de una categoría por sistema.
3. Prioriza la recogida, el análisis y la reparación en función de las necesidades de la investigación, el impacto en el negocio, *etc.*

Recogida de pruebas

- Priorizar en base al plan de investigación
- Recoger datos de respuesta en vivo utilizando Microsoft Defender for Endpoint (MDE).
- Recoger los registros relevantes de los sistemas (si no forman parte de la respuesta en vivo), agregadores, SIEM o consolas de dispositivos.
- Recoger la imagen de la memoria, si es necesario y si no forma parte de la respuesta en vivo, utilizando WinPmem (<https://github.com/Velocidex/WinPmem>).

- Recoger la imagen del disco, si es necesario, utilizando FTK Imager (<https://www.exterro.com/ftk-imager>).
- Mantener cadena de custodia: quién recogió qué, cuándo, de dónde, y cómo se almacenó (incluya hashes cuando aplique).

Considere la posibilidad de recopilar los siguientes artefactos como evidencia, ya sea en tiempo real (*por ejemplo*, a través de EDR o un SIEM) o bajo demanda:

Ejemplo de artefactos útiles

Priorización recomendada (CyberConsulting):

- Identidad/correo: logs de inicio de sesión, MFA, sesiones, reglas de buzón, reenvíos, delegaciones, cambios de permisos.
- Endpoint/servidor: alertas EDR, árbol de procesos, conexiones salientes, cambios de persistencia.
- Red: firewall/VPN, DNS/proxy.
- Web/tienda externalizada: logs de acceso, cambios de ficheros, usuarios admin, despliegues/updates.
- Procesos en ejecución
- Servicios en ejecución
- Hashes ejecutables
- Aplicaciones instaladas
- Usuarios locales y de dominio
- Puertos de escucha y servicios asociados
- Configuración de resolución del sistema de nombres de dominio (DNS) y rutas estáticas
- Conexiones de red establecidas y recientes
- Clave de ejecución y otra persistencia de la ejecución automática
- Tareas programadas y trabajos cron
- Artefactos de ejecución pasada (por ejemplo, Prefetch y Shimcache)
- Registros de eventos
- Política de grupo y artefactos WMI
- Detecciones antivirus
- Binarios en ubicaciones de almacenamiento temporal
- Credenciales de acceso remoto

- Telemetría de conexiones de red (por ejemplo, netflow, permisos de cortafuegos)
- Tráfico y actividad de DNS
- Actividad de acceso remoto, incluido el Protocolo de Escritorio Remoto (RDP), la red privada virtual (VPN), SSH, la informática de red virtual (VNC) y otras herramientas de acceso remoto
- Cadenas de identificadores de recursos uniformes (URI), cadenas de agentes de usuario y acciones de aplicación del proxy
- Tráfico web (HTTP/HTTPS)

Analizar las pruebas

- Priorizar basándose en el plan de investigación
- Analizar y clasificar los datos de la respuesta en vivo
- Analizar la memoria y las imágenes de disco (es decir, realizar análisis forenses)
- Analizar el malware
- *OPCIONAL*: Enriquecer con investigación e inteligencia
- Documentar nuevos indicadores de compromiso (IOCs)
- Actualizar el archivo del caso

Ejemplo de indicadores útiles

Priorización recomendada (CyberConsulting):

- Correlaciones temporales: “correo recibido” → “clic/descarga” → “login anómalo” → “cambios en buzón / OAuth / permisos”.
- Sign-ins anómalos: país/ASN inusual, impossible travel, nuevas apps OAuth, tokens recién emitidos.
- Señales de ransomware: borrado de VSS, I/O masivo, renombrado de ficheros, accesos SMB laterales.
- Señales de exfiltración: picos de subida, exports masivos, acceso a repositorios fuera de patrón.
- Comportamiento inusual de autenticación (*e.*, frecuencia, sistemas, hora del día, ubicación remota)
- Nombres de usuario con formato no estándar
- Binarios no firmados que se conectan a la red
- Balizamiento o transferencias de datos significativas
- Solicitudes de línea de comandos PowerShell con comandos codificados en Base64

- Actividad excesiva de RAR, 7zip o WinZip, especialmente con nombres de archivo sospechosos
- Conexiones en puertos no utilizados previamente.
- Patrones de tráfico relacionados con el tiempo, la frecuencia y el recuento de bytes
- Cambios en las tablas de enrutamiento, como la ponderación, las entradas estáticas, las pasarelas y las relaciones entre pares.

Iterar la investigación

Actualizar el plan de investigación y repetir hasta el cierre.

Remediar

Investigar, Remediar y Comunicar en paralelo, utilizando equipos separados, si es posible. El Incident Commander coordinará estas actividades. Notifique al Incident Commander si hay pasos que el equipo debe considerar

Actualización del plan de remediación

1. Revise el archivo del incidente en <https://share.cyberconsulting.com/sites/IR/Incidents/<INC-CODENAME>> utilizando el nombre del incidente
2. Revise los playbook aplicables.
3. Revise la lista de recursos de respuesta.
4. Considere qué tácticas del atacante están en juego en este incidente. Utilice la lista de MITRE ATT&CK (*i.*, Persistencia, Escalada de Privilegios, Evasión de la Defensa, Acceso a Credenciales, Descubrimiento, Movimiento Lateral, Ejecución, Recolección, Exfiltración y Mando y Control), o un marco similar.
5. Desarrollar remedios para cada táctica en juego, en la medida en que sea factible teniendo en cuenta las herramientas y los recursos existentes. Considere remedios para Proteger, Detectar, Contener, y Erradicar cada comportamiento del atacante.
6. Priorizar en base a la estrategia de tiempo, el impacto y la urgencia.
7. Documentar en el archivo de incidentes.

Utilice marcos de seguridad de la información (infosec) como inspiración, pero **no utilice la reparación de incidentes como sustituto de un programa de infosec con un marco apropiado.** Utilícelos para complementarse.

Protección

“¿Cómo podemos evitar que la táctica X se repita o reducir el riesgo?
¿Cómo podemos mejorar la protección futura?”

Utilice lo siguiente como punto de partida para la corrección de la protección:

- Parchear las aplicaciones.
- Parchear los sistemas operativos.
- Actualice las firmas de IPS de la red y del host.
- Actualizar las firmas de protección de puntos finales/EDR/antivirus.
- Reducir las ubicaciones con datos críticos.
- Reducir las cuentas administrativas o privilegiadas.
- Habilitar la autenticación multifactor.
- Reforzar los requisitos de las contraseñas.
- Bloquear los puertos y protocolos no utilizados en los límites del segmento y de la red, tanto entrantes como salientes.
- Poner en lista blanca las conexiones de red para los servidores y servicios críticos.

Detección

“¿Cómo podemos detectar esto en los nuevos sistemas o en el futuro?
¿Cómo podemos mejorar la detección y la investigación en el futuro?”

Utilice lo siguiente como punto de partida para la corrección de detecciones:

- Mejorar el registro y la retención de los registros del sistema, en particular de los sistemas críticos.
- Mejorar el registro de las aplicaciones, incluidas las aplicaciones SaaS.
- Mejorar la agregación de registros.
- Actualizar las firmas de IDS de la red y del host utilizando IOC.

Contención

“¿Cómo podemos evitar que esto se extienda o se agrave? ¿Cómo podemos mejorar la contención en el futuro?”

Utilice lo siguiente como punto de partida para la corrección de la contención:

- Implementar listas de acceso (ACL) en los límites de los segmentos de la red.
- Implementar bloqueos en el límite de la empresa, en múltiples capas del modelo OSI.
- Desactivar o eliminar el acceso de las cuentas comprometidas.
- Bloquear direcciones IP o redes maliciosas.
- Bloquee los dominios maliciosos.
- Actualizar las firmas de IPS y antimalware de la red y el host mediante COI.
- Retirar de la red los sistemas críticos o comprometidos.
- Póngase en contacto con los proveedores para obtener ayuda (por ejemplo, proveedores de servicios de Internet, proveedores de SaaS).
- Poner en lista blanca las conexiones de red para los servidores y servicios críticos.

- Matar o deshabilitar procesos o servicios.
- Bloquear o eliminar el acceso de proveedores y socios externos, especialmente el acceso privilegiado.

Erradicar

“¿Cómo podemos eliminar esto de nuestros activos? ¿Cómo podemos mejorar la erradicación en el futuro?”

Utilice lo siguiente como punto de partida para la remediación de la erradicación:

- Reconstruir o restaurar los sistemas y datos comprometidos a partir de un estado bueno conocido.
- Restablecer las contraseñas de las cuentas.
- Eliminar cuentas o credenciales hostiles.
- Borrar o eliminar malware específico (¡difícil!).
- Implementar proveedores alternativos.
- Activar y migrar a ubicaciones, servicios o servidores alternativos.

Elegir el momento de la reparación

Determine la estrategia de plazos -cuando se llevarán a cabo las acciones de remediación- involucrando al Incident Commander, a los SME y propietarios del sistema, a los SMEs y propietarios de la unidad de negocio, y al equipo ejecutivo. Cada estrategia es apropiada en diferentes circunstancias:

- Elija la reparación **inmediata** cuando sea más importante detener inmediatamente las actividades del atacante que seguir investigando. Por ejemplo, una pérdida financiera en curso, o un fracaso de la misión en curso, una pérdida de datos activa, o la prevención de una amenaza significativa inminente.
- Elija una reparación **retrasada** cuando sea importante completar la investigación o no alertar al atacante. Por ejemplo, el compromiso a largo plazo de un atacante avanzado, el espionaje corporativo o el compromiso a gran escala de un número desconocido de sistemas.
- Elija la remediación **combinada** cuando las circunstancias inmediatas y retardadas se apliquen en el mismo incidente. Por ejemplo, la segmentación inmediata de un servidor o red sensible para cumplir con los requisitos reglamentarios mientras se investiga un compromiso a largo plazo.

Ejecutar la remediación

- Evaluar y explicar los riesgos de las acciones de remediación a las partes interesadas. Para acciones con impacto operativo (cortes, reseteos masivos, aislamientos), el IC debe obtener aprobación del propietario del servicio (y de Dirección (direccion@cyberconsulting.com) si aplica) y dejarlo registrado en el archivo del incidente.

- Implementar inmediatamente aquellas acciones de remediación que afecten poco o nada al atacante (a veces llamadas “acciones de postura”). Por ejemplo, muchas de las acciones de protección y detección anteriores son buenas candidatas.
- Programar y asignar acciones de remediación de acuerdo con la estrategia de tiempo.
- Ejecute las acciones de corrección en lotes, como eventos, para lograr la máxima eficacia y el mínimo riesgo.
- Documentar el estado de ejecución y el tiempo en el archivo de incidentes, especialmente para las medidas temporales.

Iterar la remediación

Actualizar el plan de remediación y repetir hasta el cierre.

Comunicar

- Investigar, Remediar y Comunicar en paralelo, utilizando equipos separados, si es posible. Notifique al Incident Commander si hay pasos que el equipo debe considerar

Toda comunicación debe incluir la información más precisa disponible. Muestre integridad. No comunicar especulaciones.

Comunicación Interna

Notificar y actualizar a las partes interesadas

- Comunicarse con las partes interesadas como parte de las llamadas iniciales y de actualización, así como a través de actualizaciones basadas en eventos en la llamada y el chat.
- Coordinar las actualizaciones independientes (*e.*, ejecutivas, legales) según sea necesario, pero con la menor frecuencia posible, para mantener el foco en la investigación y la reparación.
- Concéntrese en la mejor evaluación del vector, el impacto, el resumen y los aspectos más destacados de la línea de tiempo, incluidos los pasos de remediación. No especule.

Notificar y actualizar la organización

- **No** notifique o actualice al personal que no responde hasta que el Incident Commander lo autorice, en particular si existe el riesgo de una amenaza interna.
- Coordine las actualizaciones de los equipos o de toda la organización con los ejecutivos y la dirección de la empresa.

- Concéntrese en la mejor evaluación del vector, el impacto, el resumen y los aspectos más destacados de la línea de tiempo, incluidos los pasos de remediación. No especule.

Crear Informe de Incidentes

- Tras el cierre del incidente, capture la información en el archivo del incidente para su distribución utilizando el formato en <https://wiki.cyberconsulting.com/ir/templates/incident-report>. **Si los informes de vector, impacto, resumen, línea de tiempo y actividad están completos, esto puede ser totalmente automatizado.**
- Distribuir el informe de incidentes a lo siguiente: seguridad@cyberconsulting.com; it-ops@cyberconsulting.com; legal@cyberconsulting.com; dpo@cyberconsulting.com; direccion@cyberconsulting.com.
- El informe debe incluir como mínimo: severidad, vector, alcance, impacto, acciones ejecutadas, estado final y acciones pendientes.

Comunicar al exterior

Notificar a los reguladores

- **No** notifique ni ponga al día al personal que no ha respondido hasta que el Incident Commander lo autorice.
- Notificar a los organismos reguladores (por ejemplo, HIPAA/HITRUST, PCI DSS, SOX) si es necesario y de acuerdo con la política.
- Coordinar los requisitos, el formato y los plazos con el Compliance/DPO (dpo@cyberconsulting.com).

Notificar a los clientes

- **No** notifique o actualice al personal que no responde hasta que el Incident Commander lo autorice.
- Coordine las notificaciones a los clientes con Comunicación (comunicacion@cyberconsulting.com).
- Incluya la fecha en el título de cualquier anuncio, para evitar confusiones.
- No utilice tópicos como “nos tomamos la seguridad muy en serio”. Céntrese en los hechos.
- Sea honesto, acepte la responsabilidad y presente los hechos, junto con el plan para prevenir incidentes similares en el futuro.
- Sea lo más detallado posible con la línea de tiempo.
- Sea lo más detallado posible en cuanto a la información que se vio comprometida y cómo afecta a los clientes. Si estábamos almacenando algo que no debíamos, sé honesto al respecto. Saldrá a la luz más tarde y será mucho peor.
- No hablemos de las partes externas que podrían haber causado el problema, a menos que ya lo hayan hecho público, en cuyo caso enlazaremos con su

información. Comuníquese con ellos de forma independiente (ver Notificar a los proveedores)

- Publique la comunicación externa lo antes posible. Las malas noticias no mejoran con el tiempo.
- Si es posible, contacte con los equipos de seguridad internos de los clientes antes de notificar al público.

Notificar a los proveedores y socios

- **No** notifique o actualice al personal que no responde hasta que el Incident Commander lo autorice.
- Si es posible, póngase en contacto con los equipos de seguridad internos de los proveedores y socios antes de notificar al público.
- Céntrese en los aspectos específicos del incidente que afectan o implican al proveedor o socio.
- Coordine los esfuerzos de respuesta y comparta la información si es posible.

Notificar a las Fuerzas de Seguridad

- **No** notifique o actualice al personal que no responde hasta que el Incident Commander lo autorice.
- Coordinar con Dirección (direccion@cyberconsulting.com) y Legal (legal@cyberconsulting.com) antes de interactuar con las fuerzas del orden.
- Póngase en contacto con las fuerzas del orden locales en Policía Nacional (091) / Guardia Civil (062).
- Póngase en contacto con el FBI en N/A (España) — sustituir por contacto nacional/INCIBE-CERT o a través del Internet Crime Complaint Center (IC3).
- Póngase en contacto con los operadores de los sistemas utilizados en el ataque, sus sistemas también pueden haber sido comprometidos.

Contactar con el servicio de asistencia de respuesta externa

- Póngase en contacto con SecurityResponse Iberia (<https://securityresponse.example>) para que le ayude a evaluar el riesgo, la gestión de incidentes, la respuesta a los mismos y el apoyo posterior al incidente.
- Póngase en contacto con PR & Comunicación Externa (<https://pr-cyber.example>) para que le ayude con las relaciones públicas y la comunicación externa.
- Póngase en contacto con Seguro Ciber (poliza CYB-2026-0001) para obtener ayuda con el seguro cibernético.

Compartir Inteligencia

- Comparta los IOCs con Infragard si procede.
- Comparta los IOCs con su ISAC de servicio a través de INCIBE-CERT (<https://www.incibe.es/incibe-cert>), si procede.

Recuperación

Objetivo: volver a operar **de forma controlada y segura**, evitando reinfección o pérdida adicional.

La recuperación suele estar dirigida por las unidades de negocio y los propietarios de los sistemas. Tome medidas de recuperación sólo en colaboración con las partes interesadas pertinentes.

1. Poner en marcha un plan de continuidad de negocio/recuperación de desastres: Por ejemplo, considerar la migración a ubicaciones operativas alternativas, sitios de conmutación por error, sistemas de copia de seguridad.
2. Integrar las acciones de seguridad con los esfuerzos de recuperación de la organización.
3. Definir prioridades de servicio (mínimo viable) y dependencias antes de restaurar (por ejemplo: identidad/correo → acceso remoto/VPN → ficheros/CRM → resto).
4. Validar backups/snapshots: integridad, fecha y ausencia de indicadores (si hay duda, restaurar en entorno aislado primero).
5. Restaurar de forma gradual y monitorizada (EDR/SIEM), confirmando que no reaparecen IOCs.
6. Documentar tiempos de recuperación (RTO/RPO reales) y gaps detectados.

Cierre del incidente

Un incidente se considera “cerrado” cuando:

- El vector está mitigado (o controlado) y el atacante no mantiene acceso.
- El impacto está contenido y los servicios críticos están recuperados (o en plan de recuperación aceptado).
- Se han rotado/invalidado credenciales/tokens necesarios.
- La documentación mínima está completa (línea de tiempo + acciones + evidencias principales).

Tras el cierre:

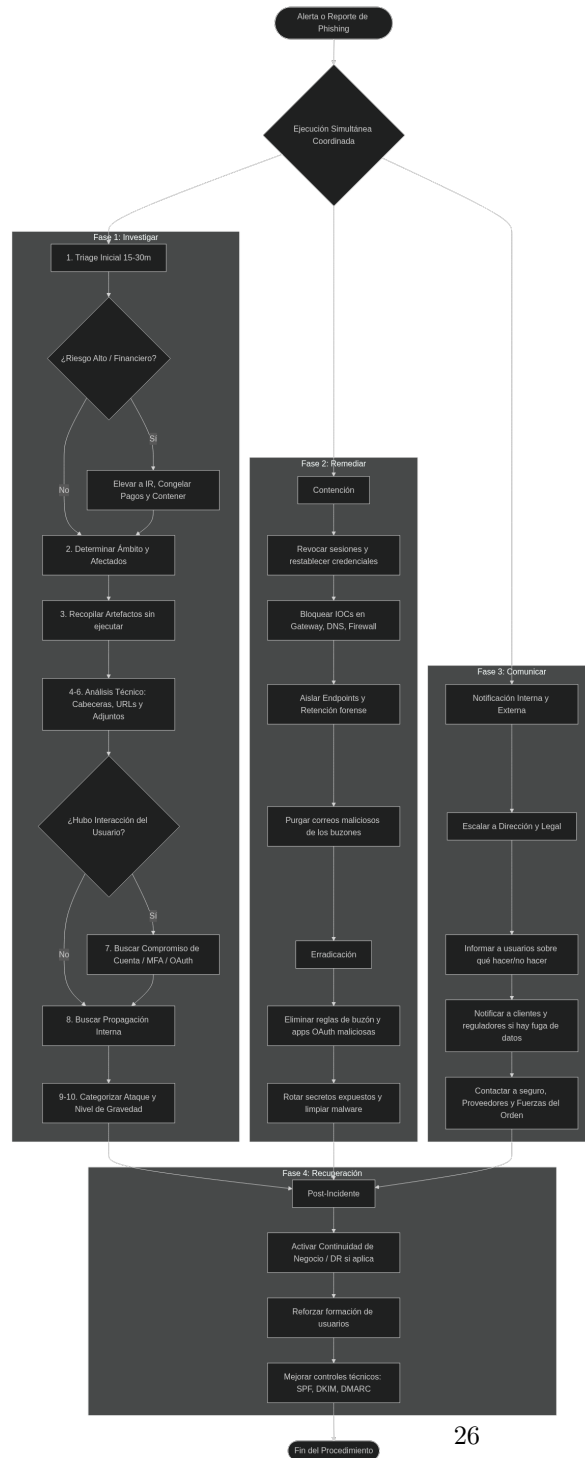
- Programar AAR según 5 días laborables y asistentes Incident Commander; Seguridad; IT Ops; Propietarios de servicio; Legal; DPO/Compliance; Comunicación.
- Crear/actualizar acciones correctivas (hardening, detección, formación, proveedores).

Playbooks

Los playbooks siguientes se incluyen a continuación como anexos operativos.

Playbook: Phishing

Diagrama de Flujo del Proceso



Investigar, remediar (contener, erradicar) y comunicar en paralelo.

Asigne pasos a individuos o equipos para que trabajen simultáneamente, cuando sea posible; este playbook no es meramente secuencial. Utilice su mejor criterio.

Investigar

OBJETIVO: Ampliar los pasos de investigación (preguntas, artefactos y estrategias) para phishing, incluyendo compromiso de cuenta y campañas internas.

Implicaciones típicas en phishing: * **BEC/fraude de facturas** dirigido a Facturación, Compras, Ventas y Dirección. * **Robo de credenciales** para correo, nube/almacenamiento, CRM/ERP y accesos remotos. * **Compromiso de RRSS** (suplantación y estafa a clientes). * **Captura de datos** por formularios de la web/tienda (phishing “inbound”) o suplantación de marca.

Regla de oro: preserve evidencia primero. Evite reenviar el correo “tal cual” (puede propagar enlaces/adjuntos); si es necesario compararlo, hágalo como adjunto (.eml/.msg) o mediante herramientas de seguridad.

1. Triage rápido (primeros 15–30 min)

- Confirmar si es (a) phishing “solo” (sin interacción), (b) phishing con interacción (clic/credenciales/descarga), o (c) compromiso de cuenta/buzón (phishing desde cuenta interna).
- Preservar evidencia mínima:
 - Captura de pantalla del correo.
 - Mensaje original en formato .eml/.msg (incluye cabeceras completas) y el Message-ID si está disponible.[4]
- Abrir/actualizar ticket y asignar un responsable de investigación + un responsable de contención.
- Determinar si hay **riesgo financiero inmediato** (cambio de cuenta bancaria, pago urgente, compra de tarjetas regalo, etc.). Si existe, notificar y coordinar de inmediato con **Facturación/Compras** para congelar/validar pagos por canal alternativo.
- Si hay riesgo alto (credenciales entregadas, pago iniciado, malware ejecutado, o cuenta interna comprometida), elevar inmediatamente a IR e iniciar contención (no espere al análisis completo).[1]

2. **Ámbito del ataque** Normalmente se le notificará que se está produciendo un posible ataque de phishing, ya sea por parte de un usuario, cliente o socio.

- Determinar el **número total de usuarios afectados**.
- Comprender **las acciones de los usuarios** ante el correo (*p. ej.*, ¿descargaron el adjunto?, ¿visitaron el sitio suplantado?, ¿introdujeron credenciales?, ¿aprobaron una solicitud MFA?, ¿autorizaron una app OAuth?, ¿realizaron una transferencia/pago?).[5]
- Identificar **áreas especialmente sensibles** por el negocio:

- Facturación/Compras/Ventas (pagos, cuentas bancarias, órdenes de transferencia, datos de proveedores)
 - RRHH (nóminas, datos personales)
 - Legal/Dirección (documentación sensible)
 - TIC/Seguridad (accesos y credenciales)
 - Encontrar la actividad potencialmente relacionada. Comprueba:
 - Redes Sociales
 - Cualquier otro correo electrónico sospechoso.
 - Correos electrónicos con enlaces a URLs externas y desconocidas.
 - Correos electrónicos de no-retorno o no-entregables.
 - Cualquier tipo de notificación de actividad sospechosa.
3. **Recopilar artefactos del mensaje (sin ejecutarlo)** Analice el mensaje utilizando un dispositivo/entorno seguro (es decir, **no** abrir adjuntos ni seguir enlaces en equipos con credenciales o acceso a datos sensibles).
- Recopilar y registrar:
 - Quién recibió el mensaje (incluyendo listas de distribución) y en qué buzón/canal llegó.
 - Quién era el objetivo real (puede diferir de los destinatarios).
 - Remitente visible (**From**) y remitente real/envelope (**Return-Path**), **Reply-To** y **To/Cc**.
 - Asunto, cuerpo, idioma, urgencia, narrativa y solicitud.
 - Adjuntos (nombre, tipo, tamaño) (**no** abrir adjuntos fuera de procedimientos).
 - Enlaces: URLs, dominios y hosts (**no** seguir enlaces; extraerlos de forma segura).
 - Cabeceras completas y cadena **Received** (IPs/hosts), **Message-ID**, resultados SPF/DKIM/DMARC.[6]
 - “Peculiaridades” (typos, dominios parecidos, display name suplantado, “invoice/HR”, QR, etc.).
 - Herramientas típicas (ejemplos): analizador de cabeceras de su suite de correo, SIEM, y analizadores externos de cabeceras (solo pegando texto).[7]
4. **Analizar cabeceras y autenticación del correo**
- Verificar:
 - ¿Falló SPF/DKIM/DMARC? ¿Hay alineación? ¿Hay indicios de spoofing del dominio legítimo?[8]
 - ¿El **Reply-To** apunta a otro dominio? ¿Hay **From** con nombre legítimo pero dominio no legítimo?
 - ¿La cadena **Received** tiene saltos sospechosos o infraestructura “throwaway”?
 - ¿Hay **Authentication-Results** inesperados o inconsistentes?
5. **Analizar URLs, dominios y hosting (de forma pasiva)**
- Normalizar y extraer indicadores:
 - Resolver redirecciones de forma segura (no en navegador normal) y capturar URL final.
 - Detectar homógrafos/punycode, subdominios engañosos y ty-

- posquatting.[9]
- Enriquecer dominios/URLs:
 - WHOIS/RDAP, ASN, hosting, certificado TLS, reputación y “first seen”.
 - Búsqueda de dominios relacionados (OSINT) a partir de registros.[10]
- Envíos típicos a servicios de análisis:
 - URLs/archivos/hashes a VirusTotal.
 - URLs a urlscan.io (si su política lo permite).
 - Sandboxes para adjuntos/URLs, según procedimiento (p. ej. Cuckoo, Hybrid Analysis, Joe Sandbox, VMray).
- 6. **Analizar adjuntos (si aplica) y posible malware**
 - Extraer hash (SHA-256), tipo real (MIME/magic) y metadatos sin ejecutar.
 - Revisar si el adjunto es una técnica común: HTML smuggling, documentos con macros, ISO/IMG, LNK, OneNote, etc.[11]
 - Si hay ejecución/descarga: coordinar con endpoint/EDR para aislar host, recopilar artefactos (proceso padre/hijo, persistencia, conexiones), y preservar para forense.
- 7. **Buscar señales de compromiso de cuenta (si hubo interacción o indicios)**
 - Si el usuario introdujo credenciales, aprobó MFA, o autorizó una aplicación:
 - Revisar logs de autenticación del IdP/SSO: inicios de sesión anómalos, “impossible travel”, nuevos dispositivos, saltos de IP/ASN, fallos repetidos, cambios de MFA.[12]
 - Revisar si hay “fatigue”/bombardeo de MFA y patrones de aprobación inusuales.[13]
 - Revisar creación de reglas de buzón, reenvíos, delegaciones, bandejas ocultas, cambios de firma, y envíos salientes sospechosos (típico en BEC/compromiso de buzón).
 - Revisar consentimientos OAuth/apps “recientemente autorizadas” (phishing de consentimiento) y permisos concedidos.[14]
 - Revisar accesos y actividad anómala en **CRM/ERP** y en **almacenamiento en la nube/servidor de ficheros** (descargas masivas, borrados, particiones externas, creación de usuarios/roles).
- 8. **Buscar propagación / campaña interna**
 - Buscar correos similares en el entorno (por asunto, remitente, dominio, URL, hash, texto del cuerpo) para dimensionar la campaña.
 - Si el phishing sale de una cuenta interna: tratar como **compromiso de cuenta/buzón** y ampliar alcance a destinatarios internos y externos.
- 9. **Categorizar el tipo de ataque** (para elegir contención/erradicación)
 - **Robo de credenciales** (página de login falsa), **phishing de consentimiento OAuth**, **malware delivery**, **BEC/fraude de facturas**,

QR phishing, smishing/vishing, callback phishing (número de teléfono en el correo).[5]

- **OBJETIVO:** Crear playbooks adicionales para BEC y para compromiso de buzón si son incidentes frecuentes.

10. **Determinar la gravedad** Considere:

- Si la seguridad pública o personal está en riesgo
- Si los datos personales (u otros datos sensibles) están en riesgo
- Si hay indicios de **compromiso de cuenta o ejecución de malware**
- Número de activos afectados
- El impacto preliminar en el negocio
- Si los servicios se ven afectados
- Si se pueden controlar/registrar los sistemas críticos
- **Alta** (ejemplos): credenciales entregadas, MFA aprobada, OAuth consentido, correo enviado desde cuenta interna, pago iniciado, malware ejecutado.
- **Media:** clic sin credenciales y sin descarga, pero con exposición de datos (p. ej., tracking, recolección de información), o campaña amplia.
- **Baja:** reportes aislados sin interacción y con bloqueo sencillo.

Remediar

- **Planificar eventos de remediación** en los que estos pasos se pongan en marcha juntos (o de forma coordinada), con los equipos adecuados listos para responder a cualquier interrupción.
- **Considere el momento y las compensaciones** de las acciones de remediación: su respuesta tiene consecuencias.

Contener **OBJETIVO:** Especificar herramientas y procedimientos internos para cada paso (suite de correo, EDR, SIEM, DNS/proxy, IAM/SSO, MDM).

- **Contener cuentas potencialmente afectadas** (prioridad si hubo interacción):
 - Restablecer credenciales y **revocar sesiones/tokens** (no solo “cambiar password”).
 - Revisar/forzar MFA (idealmente MFA resistente a phishing, cuando sea posible).[13]
 - Reducir temporalmente el acceso a sistemas/datos críticos hasta concluir investigación.
 - Si hay sospecha de compromiso de buzón: deshabilitar reenvíos externos, revisar reglas y permisos.
 - Si el impacto puede alcanzar **CRM/ERP** o repositorios compartidos (nube/servidor de archivos), limitar temporalmente comparticiones externas y revisar accesos privilegiados.
- **Bloquear por indicadores (IOCs)** descubiertos:
 - Bloquear dominios/URLs/IPs mediante DNS, firewall, proxy y/o

SWG.

- Bloquear mensajes por remitente/dominio, asunto, URLs y hashes/adjuntos en el gateway/servicio de correo.
- Añadir reglas temporales de detección en SIEM/EDR/IDS para alertar ante accesos a IOCs.
- **Retención forense y preservación**
 - Conservar copias forenses de mensajes (incluyendo cabeceras) y resultados de análisis.
 - Conservar evidencias de autenticación (logs), auditoría del buzón y actividad de endpoints.
- **Eliminar/purgar mensajes relacionados**
 - Retirar el correo de bandejas de entrada (o ponerlo en cuarentena) para reducir más interacción.
- **Contener endpoints y móviles si aplica**
 - Aislar endpoint(s) donde se haya abierto/ejecutado adjunto.
 - Considerar acciones MDM (bloqueo/borrado) en móviles, equilibrando impacto forense.
- **Asistencia externa y coordinación**
 - Considerar apoyo externo (IR, forense, fraude/BEC) si hay compromiso o pérdida financiera.
 - Si el phishing afecta a la **web/tienda** (suplantación de marca, formularios abusados, o contenido comprometido), coordinar con el proveedor de hosting externo y revisar integridad y logs disponibles.
- **Higiene técnica**
 - Confirmar actualizaciones de antimalware/EDR y parches relevantes.

Erradicar OBJETIVO: Personalizar pasos de erradicación para su entorno (correo/IAM/endpoint).

- Eliminar reglas maliciosas del buzón, reenvíos, delegaciones no autorizadas y “apps” OAuth no aprobadas.
- Rotar secretos/tokens y claves que pudieran haberse expuesto (incluye API tokens, tokens de sesión, claves de apps).
- Revisar y endurecer políticas de acceso (p. ej., acceso condicional) si el vector fue credenciales.
- Eliminar malware/persistencia del endpoint (reimagen si procede), y confirmar que no hay reinfección.

Comunicar

OBJETIVO: Personalizar los pasos de comunicación para phishing (quién comunica, mensajes y canales).

OBJETIVO: Especificar herramientas y procedimientos (incluyendo quién participa) o remitir al plan general.

1. Elevar el incidente y comunicarlo a la dirección según el procedimiento

2. Documente el incidente según el procedimiento (y, si aplica, informe a autoridades/cert/seguero).[1]
3. Comunicarse con los asesores jurídicos internos y externos según el procedimiento, incluyendo discusiones sobre el cumplimiento, la exposición al riesgo, la responsabilidad, el contacto con las fuerzas del orden, *etc.*
4. Comunicación con los usuarios (interna)
 1. Comunicar las actualizaciones de la respuesta a incidentes según el procedimiento
 2. Comunicar el impacto del incidente **y** las acciones de respuesta al mismo (e.j., contención: “¿Por qué está caído el archivo compartido?”)
 3. Comunicar los requisitos: “¿Qué deben hacer y no hacer los usuarios?” (p. ej., no reenviar el correo, reportarlo, cambiar contraseña si se interactuó, no aprobar solicitudes MFA inesperadas)
5. Comunicar a los clientes
 1. Centrarse especialmente en aquellos cuyos datos se vieron afectados
 2. Genere las notificaciones requeridas en base a las regulaciones aplicables (particularmente aquellas que puedan considerar el phishing como una violación de datos o que requieren notificaciones de otro tipo)
 3. Si hubo suplantación en **RRSS** o en la **web/tienda**, comunicarlo en los canales oficiales (web/redes) con un mensaje breve y verificable (cómo identificar comunicaciones legítimas, canales de contacto, y qué hacer si fueron víctimas).
6. Contactar con el/los proveedor/es de seguros
 1. Discutir qué recursos pueden poner a disposición, qué herramientas y proveedores apoyan y pagarán, *etc.*
 2. Cumplir con los requisitos de presentación de informes y reclamaciones para proteger la elegibilidad.
7. Considere la posibilidad de notificar e implicar a las fuerzas del orden
 1. Aplicación de la ley local
 2. Aplicación de la ley a nivel estatal o regional
 3. Fuerzas de seguridad nacionales o europeas
8. Comuníquese con los proveedores de seguridad y de TI
 1. Notifique y colabore con proveedores gestionados para el procedimiento
 2. Notifique y colabore con consultores de respuesta ante incidentes para el procedimiento

Recuperación

OBJETIVO: Personalizar los pasos de recuperación para phishing (correos, cuentas, endpoint y controles preventivos).

OBJETIVO: Especificar herramientas y procedimientos para cada paso, a continuación.

1. Poner en marcha un plan de continuidad de negocio/recuperación de de-

sastres si el compromiso implica interrupciones de negocio: *e.j.*, considerar la migración a ubicaciones operativas alternativas, clústers de conmutación por error, sistemas de copias de seguridad.

2. Reforzar los programas de formación sobre los ataques de phishing sospechosos. Los principales indicadores de sospecha pueden ser:
 - Errores ortográficos en el mensaje o en el asunto
 - Nombres de remitentes que parezcan de teléfono, incluida la falta de coincidencia entre el nombre y la dirección de correo electrónico.
 - Direcciones de correo electrónico personales para asuntos oficiales (e.j., correos electrónicos de gmail o yahoo de colegas de trabajo)
 - Líneas de asunto marcadas con “[EXTERNO]” en correos electrónicos que parecen internos.
 - enlaces maliciosos o sospechosos
 - Recibir un correo electrónico o un archivo adjunto que no se esperaba, pero que proviene de alguien conocido (contactar con el remitente antes de abrirlo).
 - Informar de actividades sospechosas al departamento de TI o de seguridad.
3. Asegúrese de que el personal de TI y de seguridad está al día de las técnicas de phishing más recientes.
4. Determine si ha fallado algún control al ser víctima de un ataque y rectifíquelo. He aquí una buena fuente a tener en cuenta tras un ataque de phishing.
5. Mejorar controles de correo (cuando aplique):
 - Revisar/fortalecer SPF, DKIM y DMARC (y su monitoreo) para su dominio.[8]
 - Revisar políticas anti-phishing/anti-spoofing, protección de enlaces/adjuntos, y reporting.
 - Aumentar visibilidad: retención de logs, alertas de reglas de buzón y consentimientos OAuth.

Recursos

Referencia: Acciones del usuario ante la sospecha de un ataque de phishing OBJETIVO: Personalizar los pasos para usuarios (botón de reportar phishing, contacto, tiempos de respuesta).

1. Mantenga la calma y respire profundamente.
2. No haga clic en enlaces ni abra adjuntos. No responda al remitente.
3. Haga fotos/capturas de lo que ha notado: el mensaje de phishing, el enlace (si lo vio), la información del remitente.
4. Si ya hizo clic o introdujo credenciales, **repórtelo igualmente**; esto reduce el impacto.

5. Si realizó un pago o facilitó datos bancarios por petición del correo/mensaje, contacte inmediatamente con **Facturación/Compras** además de con el servicio de ayuda.
6. Tome notas (voz o papel). Todo ayuda. Documente lo siguiente:
 1. ¿Qué ha notado?
 2. ¿Por qué pensó que era un problema?
 3. ¿Qué estaba haciendo en el momento en que lo detectó?
 4. ¿Cuándo se produjo por primera vez, y con qué frecuencia desde entonces?
 5. ¿Dónde estaba cuando ocurrió y en qué red? (oficina/casa/tienda, con cable/inalámbrica, con/sin VPN, *etc.*)
 6. ¿Qué sistemas está utilizando? (sistema operativo, nombre de host, *etc.*)
 7. ¿Qué cuenta utiliza?
 8. ¿A qué datos suele acceder?
 9. ¿Con quién más se ha puesto en contacto sobre este incidente y qué les ha dicho?
7. Póngase en contacto con el servicio de ayuda utilizando la línea directa de phishing o la barra de herramientas de reporte de phishing y sea lo más servicial posible.
8. No borre el correo hasta que se le indique (puede ser necesario para investigación).
9. Tenga paciencia: la respuesta puede ser perturbadora, pero está protegiendo a su equipo y a la organización. **Gracias.**

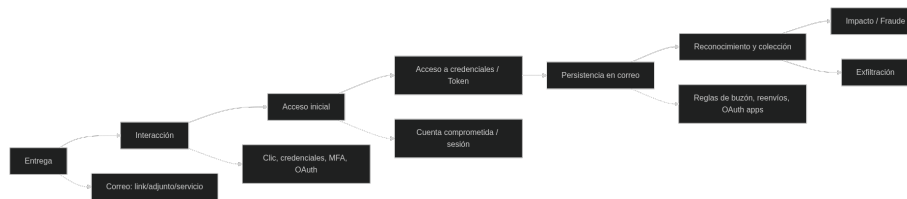
Referencia: Acciones del servicio de ayuda ante un presunto ataque phishing OBJETIVO: Personalizar los pasos para el personal del service desk ante sospecha de phishing (plantilla, automatización y escalado).

1. Mantenga la calma y respire profundamente.
2. Abra un ticket para documentar el incidente, según el procedimiento.
3. Pídale al usuario que tome fotos/capturas mostrando lo que notó: el mensaje, el enlace (si lo abrió), la información del remitente, *etc.* Si es algo que notó directamente, haga lo mismo usted.
4. Tome notas. Si se trata de un informe de usuario, haga preguntas detalladas, incluyendo:
 1. ¿Qué ha notado?
 2. ¿Por qué pensó que era un problema?
 3. ¿Qué estaba haciendo en el momento en que lo detectó?
 4. ¿Cuándo se produjo por primera vez, y con qué frecuencia desde entonces?
 5. ¿De qué redes se trata? (oficina/casa/tienda, cableada/inalámbrica, con/sin VPN, *etc.*)
 6. ¿De qué sistemas se trata? (sistema operativo, nombre de host, *etc.*)
 7. ¿De qué datos se trata? (rutas, tipos de archivos, archivos compartidos,

- bases de datos, software, *etc.*)
8. ¿Qué usuarios y cuentas están implicados? (directorio activo, SaaS, SSO, cuentas de servicio, *etc.*)
 9. ¿A qué datos suelen acceder los usuarios implicados?
 10. ¿Con quién más se ha puesto en contacto sobre este incidente y qué les ha dicho?
5. Confirme si hubo interacción: clic, descarga, credenciales, MFA, OAuth, pago.
 6. Haga las preguntas de seguimiento que sean necesarias. **Usted es parte de la respuesta a incidentes; contamos con usted.**
 7. Obtenga información de contacto detallada del usuario (domicilio, oficina, móvil), si procede.
 8. Registre toda la información en el ticket, incluyendo evidencias.
 9. Ponga en cuarentena a los usuarios y sistemas afectados (si procede).
 10. Póngase en contacto con el equipo de seguridad y prepárese para participar en la respuesta según las indicaciones: investigación, remediación, comunicación y recuperación.

Técnicas MITRE ATT&CK Relevantes en Este Playbook

Cadena de Ataque: Visualización Completa



Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Entrega	T1566: Phishing	El atacante usa correo (o servicios de mensajería) para iniciar el engaño y llevar al usuario a una acción (clic, adjunto, credenciales, MFA, OAuth).	Alertas del gateway/seguridad de correo (detonaciones por URL/adjunto), picos de correos con asuntos similares, dominios “look-alike”, y mensajes con Reply-To anómalo.

Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Entrega	T1566.002: Spearphishing Link	El correo contiene enlaces a páginas falsas (login, pago, “documento compartido”) o cadenas de redirección.	Registros de proxy/SWG/DNS con accesos a dominios recién creados, redirecciones múltiples, punycode/typosquatting, y coincidencia con IOCs extraídos del mensaje.
Entrega	T1566.001: Spearphishing Attachment	El correo incluye un adjunto que intenta ejecutar contenido activo o dejar malware (doc con macros, ISO/LNK, HTML smuggling, OneNote, etc.).	Detecciones EDR/AV al abrir el adjunto, procesos hijo inesperados (Office → PowerShell/Script), creación de ficheros en %TEMP%, y conexiones salientes tras la apertura.
Interacción	T1204: User Execution	El éxito depende de que el usuario haga clic/ejecute/autorice algo (abrir adjunto, introducir credenciales, aprobar MFA, consentir OAuth).	Telemetría del endpoint (apertura/ejecución), y correlación temporal: “correo recibido” → “clic/descarga” → “login/consentimiento” o “alerta EDR”.
Acceso inicial	T1078: Valid Accounts	Tras robar credenciales o tokens, el atacante accede como el usuario (correo, nube, VPN, SaaS).	Logs del IdP/SSO: inicio de sesión desde IP/ASN/país inusual, nuevo dispositivo, “impossible travel”, cambios de método MFA, y aumentos de fallos de autenticación previos al éxito.

Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Acceso a credenciales / Token	T1550.001: Application Access Token	En phishing de consentimiento OAuth o robo de sesión, el atacante obtiene tokens (sin necesitar password) y accede a recursos.	Auditoría del tenant/IdP: apps OAuth “recientemente autorizadas”, permisos de alto impacto (mail.read, offline_access, files.read), y actividad API anómala.
Persistencia en correo	T114.003: Email Forwarding Rule	El atacante crea reglas para reenviar/ocultar correos, mantener acceso o espiar conversaciones (típico en BEC).	Auditoría del buzón: creación/modificación de reglas, reenvíos externos, delegaciones, cambios de bandejas/reglas “mover a RSS/eliminar”, y envíos salientes sospechosos.
Reconocimiento y colección	T1087: Account Discovery	El atacante enumera usuarios/grupos para expandir alcance (campana interna o suplantación).	Logs de directorio/IdP: consultas inusuales, enumeración de directorio, creación de listas, y cambios de permisos/roles que no encajan con el comportamiento del usuario.
Exfiltración	T1041: Exfiltration Over C2 Channel	Tras comprometer cuenta/endpoint, el atacante extrae datos por canales salientes (HTTP/S, APIs, etc.).	Proxy/firewall/CASB: picos de subida, accesos masivos a ficheros/correos, descargas/exports inusuales, y conexiones a infra nueva poco frecuente para la organización.
Impacto / Fraude	T1657: Financial Theft	BEC/fraude: cambio de cuenta bancaria, pagos urgentes, compra de gift cards o manipulación de facturas.	Señales de negocio: cambios de IBAN/cuentas, solicitudes urgentes fuera de canal, modificación de PDFs/facturas, y coincidencia con compromiso de buzón (reglas/reenvíos) o suplantación en hilos reales.

Información adicional

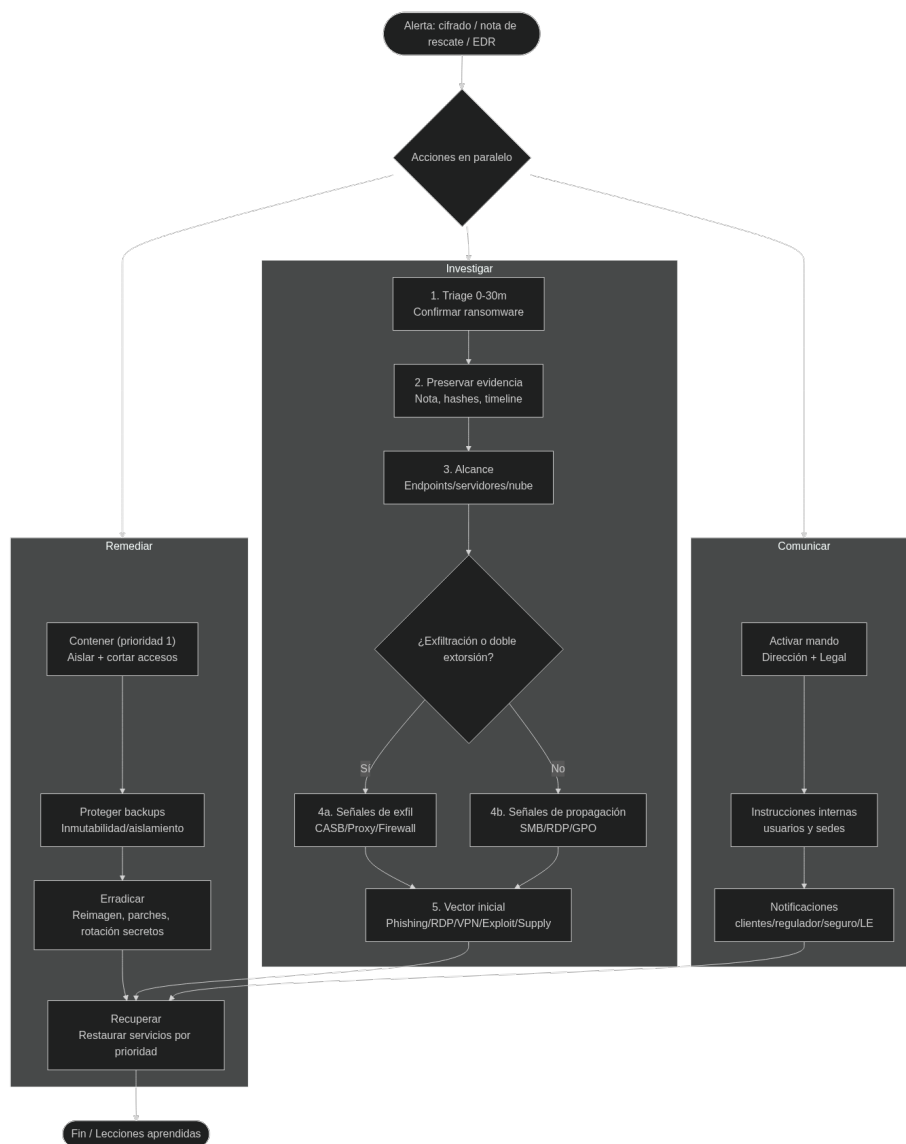
1. CISA: Report Phishing (incluye canal de reporte y orientación)
2. NIST SP 800-61 Rev. 2: Computer Security Incident Handling Guide
3. MITRE ATT&CK: Phishing (T1566)
4. RFC 5322: Internet Message Format
5. ENISA: Phishing (panorama y recomendaciones)
6. Google Admin Toolbox: Messageheader
7. Microsoft: Message Header Analyzer (MHA)
8. DMARC (RFC 7489) y SPF (RFC 7208) y DKIM (RFC 6376)
9. ICANN: IDN / Homograph attacks (conceptos)
10. Reverse WHOIS (Whoxy)
11. MITRE ATT&CK: User Execution (T1204)
12. NCSC (UK): Phishing
13. NIST: Digital Identity Guidelines (SP 800-63) - autenticación/MFA (familia)
14. Microsoft: Consent phishing (conceptos y mitigación)
15. FBI IC3: Report Internet Crime
16. INCIBE: Phishing (orientación al usuario)
17. CCN-CERT: Guías y recursos (España)
18. Ejemplos de correos de phishing (Phishing.org)
19. SecurityMetrics: 7 ways to recognize phishing emails
20. InfoSec Institute: Anti-phishing resources y best practices

Playbook: Ransomware

Investigar, remediar (contener, erradicar) y comunicar en paralelo. En ransomware, la contención es prioritaria: actúe rápido para frenar propagación y proteger copias de seguridad.

Asigne pasos a individuos o equipos para que trabajen simultáneamente, cuando sea posible; este playbook no es puramente secuencial. Utilice su mejor criterio.

Diagrama de Flujo del Proceso



Investigar

OBJETIVO: Confirmar ransomware, frenar propagación, dimensionar alcance (2 sedes + nube + servidores), y estimar impacto (operativo, datos, legal).

1. Triage rápido (primeros 0–30 min)

- Confirmar que es ransomware (no corrupción/backup defectuoso):

- nota de rescate, extensión, comportamiento EDR.
 - Identificar **sede**, usuario y equipo(s) iniciales reportados.
 - Preservar evidencia mínima (sin “limpiar” todavía):
 - Nota de rescate (archivo/imagen), nombre/extensión de ficheros, rutas afectadas.
 - Hashes de binarios/artefactos si el EDR lo permite.
 - Hora aproximada del primer síntoma; capturas de pantalla.
 - Abrir/actualizar ticket y asignar responsable de investigación + responsable de contención.
2. **Determinar alcance técnico (rápido y ampliable)**
- Endpoints: puestos, portátiles, servidores, y terminales en ambas sedes.
 - Servicios críticos: servidores de archivos, correo, CRM/ERP, aplicaciones internas, almacenamiento cloud.
 - Web/tienda externa: validar si hay impacto colateral (credenciales, paneles, integraciones), aunque el cifrado sea interno.
 - Fuentes típicas:
 - EDR/AV: detecciones, aislamiento, árbol de procesos, persistencia.
 - Logs Windows/Linux: eventos de seguridad, servicios, tareas programadas.
 - Red (firewall/VPN/IDS/DNS/proxy): conexiones C2, escaneo, picos SMB/RDP.
 - Nube/SaaS: auditoría (descargas masivas, tokens, apps autorizadas, accesos anómalos).
3. **Confirmar si hay exfiltración / doble extorsión (no esperar al final)**
- Señales: tooling de compresión/archivado, transferencia saliente sostenida, uso de servicios de subida, exports desde CRM/ERP.
 - Prioridad especial a datos: PII de clientes/proveedores, documentación laboral/fiscal, propiedad intelectual, procesos internos.
4. **Identificar vector de acceso inicial (para cortar reinfección)**
- Hipótesis típicas:
 - Phishing y robo de credenciales.
 - Exposición de RDP/VPN/portales o credenciales reutilizadas.
 - Vulnerabilidad en sistemas expuestos (correo, VPN, web, RMM).
 - Cadena de suministro (software/RMM/proveedor).
 - Recolectar evidencias: logs VPN, autenticación, correo, cambios de cuentas privilegiadas, creación de nuevos usuarios.
5. **Clasificar gravedad y priorizar**
- Número de sistemas/servidores cifrados; si hay Domain Controllers/servidores de archivos afectados.
 - Si hay backups comprometidos o repositorios de backup accesibles.
 - Impacto en facturación/ventas/compras/delivery/mantenimiento; dependencia del CRM/ERP.
 - Obligaciones de notificación si hay indicios de acceso a datos personales

(coordinar con Legal).

Remediar

- **Planificar eventos de remediación** en los que contención/erradicación/recuperación se coordinen con TIC, negocio y sedes.
- **Considere el momento y las compensaciones:** la contención agresiva puede causar caída de servicios, pero reduce propagación.

Contener (prioridad 1) OBJETIVO: Frenar propagación y proteger backups/activos críticos sin destruir evidencia.

- **Aislar sistemas comprometidos**
 - Aislar por EDR o desconexión de red (si no hay EDR): quitar cable/Wi-Fi.
 - Si el cifrado afecta a shares, **cortar accesos SMB** temporalmente (por VLAN/ACL) según criticidad.
- **Cortar accesos y tokens**
 - Deshabilitar cuentas sospechosas; reset de credenciales y **revocación de sesiones/tokens**.
 - Rotar credenciales privilegiadas y cuentas de servicio si hay indicios.
- **Proteger copias de seguridad**
 - Aislar repositorios de backup/snapshots (inmutables/offline donde sea posible).
 - Pausar jobs que puedan sobrescribir backups limpios.
- **Reducir daño por sincronización cloud**
 - Si hay clientes de sincronización (almacenamiento en la nube), pausar/deshabilitar temporalmente en equipos sospechosos para evitar que el cifrado se propague a carpetas sincronizadas.
 - Revisar auditoría del servicio cloud: borrados masivos, renombrados y descargas/exports.
- **Bloquear indicadores y activar detección**
 - Bloquear dominios/IPs/hashes conocidos (EDR/SWG/DNS/firewall).
 - Añadir reglas temporales en SIEM para: ejecución desde shares, borrado VSS, cambios GPO, picos SMB/RDP.
- **Contención organizativa (2 sedes)**
 - Instrucciones a usuarios: no conectar USBs/discos, no reiniciar equipos cifrados si se necesita forense.
 - Coordinar con seguridad física para facilitar acceso controlado a salas técnicas y registrar visitas (sin interferir con evidencia).
- **Proteger la operación financiera (si aplica)**
 - Coordinar con Facturación/Compras para pausar pagos urgentes y reforzar verificación fuera de banda (doble aprobación / llamada a contacto conocido).

Erradicar OBJETIVO: Eliminar el malware y cerrar el vector para evitar reinfección.

- **Eliminar persistencia y artefactos**
 - Identificar y eliminar: servicios, tareas programadas, claves de arranque, scripts, herramientas remotas no autorizadas.
 - Revisar Active Directory: cuentas nuevas, cambios en GPO, delegaciones y privilegios.
- **Reimagen/limpieza**
 - Reimaginar endpoints/servidores afectados desde imágenes “golden” conocidas.
 - Aplicar parches críticos (SO y software expuesto), endurecer RDP/VPN y paneles de administración.
- **Rotación de secretos**
 - Rotar credenciales privilegiadas, secretos de aplicaciones, claves API, y credenciales de integraciones (incluye nube/tienda).
- **Validación post-erradicación**
 - Confirmar ausencia de reinfección: telemetría EDR estable, no hay borrado VSS, no hay lateral SMB/RDP.

Referencia: Recursos de remediación OBJETIVO: Especifique recursos financieros, de personal y logísticos (IR externo/forense, ventanas de mantenimiento, soporte de proveedor).

Comunicar

OBJETIVO: Coordinar comunicación interna/externa minimizando especulación y cumpliendo obligaciones.

No se recomienda pagar el rescate: no garantiza recuperación y puede aumentar el riesgo y la recurrencia.[2]

1. Activar cadena de mando: Dirección/Consejo, Legal, TIC/Seguridad, y responsables de áreas críticas.
2. Comunicación interna (2 sedes): instrucciones claras (qué hacer/no hacer), canales oficiales, y estado de servicios (correo, ficheros, CRM/ERP).
3. Coordinar con Legal:
 - Evaluar notificación a clientes/proveedores/reguladores y aseguradora (si aplica), especialmente por datos personales.
 - Preservación de evidencias y requisitos contractuales.
4. Considerar notificar e implicar fuerzas del orden / CERT según procedimiento.
5. Comunicación externa (si aplica): mensaje breve y verificable; canal oficial web/RRSS si hay impacto público.

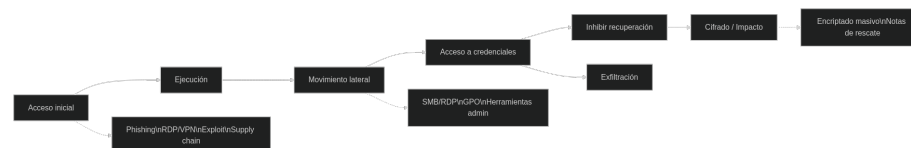
Recuperación

OBJETIVO: Restaurar operación de forma segura, priorizando servicios críticos, y evitar reinfección.

1. Definir orden de restauración por criticidad (ejemplo): identidades/AD → correo → ficheros → CRM/ERP → almacenamiento cloud → resto.
2. Restaurar desde backups limpios:
 - Verificar integridad y ausencia de IOCs antes de restaurar.
 - Preferir restauraciones parciales y por oleadas; monitorizar durante la vuelta.
3. Probar descriptores (si existen) según variante con recursos como No More Ransom.[2]
4. Reforzar controles post-incidente:
 - MFA resistente a phishing para cuentas privilegiadas y acceso remoto.
 - Segmentación entre sedes y zonas (usuarios/servidores/backups).
 - Backups 3-2-1, inmutabilidad/offline y pruebas periódicas de restauración.
 - Hardening de RDP/VPN, gestión de parches, EDR en endpoints y servidores.

Técnicas MITRE ATT&CK Relevantes en Este Playbook

Cadena de Ataque: Visualización Completa



Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Acceso inicial	T1566: Phishing	Correo con adjunto/enlace o robo de credenciales previo para entrar.	Gateway de correo + proxy/SWG: campañas, URLs nuevas, adjuntos; correlación “correo → login anómalo → ejecución”.
Acceso inicial	T1133: External Remote Services	Acceso por VPN/RDP/portales expuestos (a menudo con credenciales robadas).	Firewall/VPN: logins fuera de horario, IP/ASN inusual, nuevos dispositivos; escaneo previo y picos de intentos.

Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Acceso inicial	T1190: Exploit Public-Facing Application	Explotación de servicios expuestos (web, VPN, RMM, correo).	Logs de acceso/app + WAF/IDS: patrones de explotación, errores 500/200 sospechosos, llamadas a endpoints raros.
Ejecución	T1059: Command and Scripting Interpreter	Uso de Power-Shell/cmd/bash/python/scripts para desplegar payload y moverse.	EDR: árboles de procesos, scripts ofuscados, ejecución desde %TEMP%/shares, y conexiones de red post-ejecución.
Movimiento lateral	T1021: Remote Services	Movimiento por RDP/SMB/WinRM/SSH/SMB/RDP, accesos a servidores y puestos.	Autenticación + red: picos múltiples hosts, lateral en 2 sedes, y nuevas rutas admin.
Credenciales	T1003: OS Credential Dumping	Volcado de credenciales (LSASS, SAM) para expansión.	EDR: acceso a LSASS, herramientas conocidas, eventos de seguridad; aparición de credenciales privilegiadas en uso.
Defensa evadida	T1562: Impair Defenses	Desactivar AV/EDR, logging o tamper protections.	Alertas EDR/SIEM: servicios detenidos, exclusiones nuevas, caída de telemetría, cambios de políticas.
Inhibir recuperación	T1490: Inhibit System Recovery	Borrado de copias sombra, sabotaje de backups y snapshots.	EDR + logs Windows: eliminación de VSS, cambios en jobs de backup, accesos al repositorio de backup.
Impacto	T1486: Data Encrypted for Impact	Cifrado masivo de endpoints/servidores y shares; interrupción operativa.	Detección EDR: I/O masivo, renombrado/extensions, notas de rescate; alertas de integridad en ficheros.
Exfiltración	T1041: Exfiltration Over C2 Channel	Robo de datos para doble extorsión (por HTTPS/APIs).	Proxy/CASB/Firewall: picos de subida, destinos nuevos, descargas/exports inusuales en nube/CRM/ERP.

Recursos

Referencia: Acciones del usuario ante sospecha de ransomware

OBJETIVO: Pasos claros para usuarios (puestos, portátiles y móviles).

1. Mantenga la calma y respire profundamente.
2. Si ve cifrado o nota de rescate: **desconecte el equipo de la red** (cable/Wi-Fi). No conecte USBs/discos externos.
3. Haga fotos/capturas: nota de rescate, extensión de archivos, mensajes de error.
4. Repórtelo al service desk y siga instrucciones. **No intente “limpiar”** por su cuenta.

Referencia: Acciones del service desk ante sospecha de ransomware

OBJETIVO: Recoger datos útiles y activar contención rápida.

1. Abra ticket con prioridad alta y escale a Seguridad/TIC.
2. Recoja: usuario, sede, equipo, hora, rutas afectadas, si hay nota de rescate, si hay shares implicados.
3. Indique al usuario desconectar red y no reiniciar (salvo instrucción).
4. Coordine aislamiento por EDR/IT y documente todas las acciones.

Información adicional

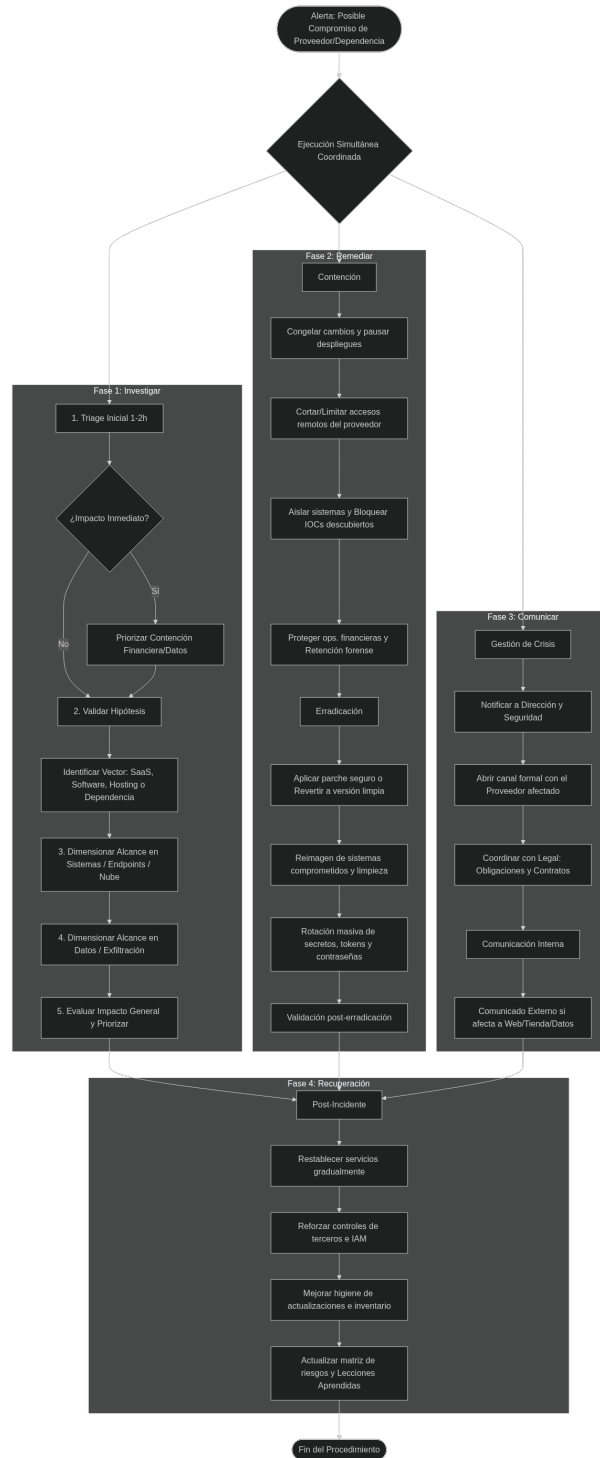
1. “Ransomware Identification for the Judicious Analyst”, Hahn (12 Jun 2019)
2. No More Ransom! (Crypto Sheriff, Q&A y herramientas de descifrado)
3. ID Ransomware
4. MITRE ATT&CK (tácticas de Initial Access e Impact)

Playbook: Compromiso de la cadena de suministro

Investigar, remediar (contener, erradicar) y comunicar en paralelo.

Asigne pasos a individuos o equipos para que trabajen simultáneamente, cuando sea posible; este libro de jugadas no es puramente secuencial. Utilice su mejor criterio.

Diagrama de Flujo del Proceso



Investigar

OBJETIVO: Confirmar si el incidente proviene de un proveedor (software/SaaS/hosting/subcontrata), dimensionar el alcance (sistemas, datos, sedes) y habilitar contención/erradicación rápidas.

Contexto típico en esta organización: * Infraestructura mixta (servidores internos + nube/almacenamiento). * Web y tienda online alojadas en un proveedor externo. * Herramientas de negocio (CRM/ERP) e integraciones con terceros. * Proveedores con acceso (TI/seguridad gestionada, subcontratas, mantenimiento, seguridad física).

1. Triage rápido (primeras 1–2 horas)

- Identificar el “eslabón” sospechoso:
 - Proveedor SaaS (correo, almacenamiento, CRM/ERP, facturación, soporte/tickets, RRSS).
 - Software on-prem (actualización reciente, agente EDR, VPN, herramienta de administración remota, backup).
 - Paquete/dependencia (librerías, plugins, extensiones, scripts).
 - Proveedor de hosting/CDN/pasarela de pago (web/tienda).
 - Subcontrata con acceso físico o lógico (incluye seguridad física, mantenimiento, proveedores que conectan dispositivos/USB).
- Capturar evidencia mínima (sin modificar sistemas si es posible):
 - Nombre del proveedor, producto, versiones, fechas de actualización, cuentas afectadas, IDs de tenant.
 - Avisos del proveedor (advisory), CVE si aplica, IOCs publicados y mitigaciones recomendadas.
 - Línea temporal preliminar: “cuándo fue actualizado / cuándo empezó el comportamiento”.
- Determinar si hay **impacto inmediato**:
 - Robo de credenciales/tokens, accesos anómalos a correo/nube/CRM/ERP.
 - Modificación de web/tienda (skimmer de pagos, redirecciones, inyección de JavaScript, malware).
 - Exfiltración de datos personales de clientes/proveedores.
 - Fraude financiero (cambio de IBAN, suplantación BEC).

2. Validar la hipótesis: ¿compromiso del proveedor o incidente interno?

- Comprobar si existen indicadores de:
 - Actualización/paquete malicioso (hashes, firmas, repositorios, cadenas de build).
 - Credenciales expuestas (phishing previo, reuse, MFA bypass, token theft).
 - Compromiso de la plataforma del proveedor (incidente público, notificación del proveedor).
 - Integración OAuth/API con permisos excesivos o consentida por usuarios.

- Clasificar el escenario principal:
 - **Software update comprometida** (supply chain software) (MITRE T1195).[5]
 - **SaaS comprometido / tenant comprometido** (acceso a datos y correo).
 - **Hosting/tienda comprometidos** (web skimming, redirecciones, inyección JS).
 - **Proveedor con acceso remoto comprometido** (RMM/PSA, VPN, cuentas de soporte).
 - **Dependencia/paquete malicioso** (registries, typosquatting, dependency confusion).
- 3. **Dimensionar el alcance (qué está afectado)**
 - Inventariar activos y servicios que usan el proveedor/producto:
 - Endpoints (PCs/portátiles/móviles), servidores internos (correo, ficheros, apps), routers/WiFi.
 - Servicios en la nube (almacenamiento, CRM/ERP, identidades/SSO si aplica).
 - Web/tienda y terceros asociados (CDN, analítica, chat, pagos).
 - Buscar “puntos de control” para detectar expansión:
 - EDR/AV: procesos, persistencia, conexiones.
 - SIEM/logs: autenticación, cambios de configuración, actividad administrativa.
 - Proxy/DNS/Firewall: dominios/hosts/ASNs sospechosos.
 - SaaS audit logs: particiones externas, descargas masivas, creación de reglas/buzones.
- 4. **Determinar el alcance en datos (qué información puede haberse expuesto)**
 - Identificar repositorios accesibles desde el proveedor/servicio afectado:
 - Datos personales de clientes/proveedores (PII), documentación fiscal/laboral.
 - Datos de gestión y funcionamiento (CRM/ERP).
 - Propiedad intelectual y procesos internos.
 - Estimar si hubo exfiltración o acceso no autorizado (descargas masivas, API calls, creación de tokens).
- 5. **Evaluar impacto y priorizar**
 - Priorizar por: datos personales, continuidad del servicio, impacto financiero/reputacional y riesgo legal.
 - Confirmar si aplica notificación a interesados/reguladores/seguros (consultar Legal).
 - Para decisiones de riesgo y exigencias a proveedores, usar como marco el enfoque de gestión de riesgos de cadena de suministro (C-SCRM).[1]

Remediar

- **Planificar eventos de remediación** en los que estos pasos se pongan en marcha juntos (o de forma coordinada), con los equipos adecuados listos

para responder a cualquier interrupción.

- **Considere el momento y las compensaciones** de las acciones de remediación: su respuesta tiene consecuencias.

Contención OBJETIVO: Frenar propagación y reducir exposición, sin destruir evidencia; coordinar con proveedores y con áreas de negocio críticas.

OBJETIVO: Especificar herramientas y procedimientos internos para cada paso (EDR, SIEM, proxy/DNS, IAM/SSO, MDM, gestión de cambios).

- **Congelar cambios relacionados**
 - Pausar despliegues/actualizaciones automáticas del producto sospechoso hasta validar integridad.
 - Congelar cambios en integraciones (API keys, webhooks, apps) hasta inventariar.
- **Reducir superficie y cortar accesos de terceros**
 - Deshabilitar temporalmente accesos de soporte/proveedor (cuentas, VPN, RMM) si existe riesgo.
 - Rotar/invalidar credenciales compartidas del proveedor y revocar tokens/sesiones.
- **Aislar sistemas potencialmente comprometidos**
 - Aislar endpoints/servidores con el software/actualización afectada.
 - Si hay impacto en web/tienda: poner en modo mantenimiento o aislar, y coordinar con hosting/CDN.
- **Bloquear IOCs y activar detección**
 - Bloquear dominios/URLs/IPs publicados por el proveedor/CSIRT.
 - Añadir reglas temporales de detección en SIEM/EDR/IDS.
- **Proteger la operación financiera (si aplica)**
 - Reforzar validación fuera de banda para cambios de IBAN/pagos (doble aprobación, llamada a contacto conocido).
 - Suspender pagos urgentes relacionados con correos/cambios recientes hasta verificar.
- **Retención forense**
 - Conservar logs de endpoints/servidores y auditorías SaaS; exportar evidencias si el proveedor tiene retención limitada.
 - Preservar instaladores/paquetes, hashes y firmas.

OBJETIVO: Considerar automatizar contención mediante orquestación (SOAR) donde exista.

Erradicar OBJETIVO: Eliminar el artefacto malicioso, cerrar el vector (proveedor/integración), y restaurar confianza mediante versiones limpias y rotación de secretos.

OBJETIVO: Especificar herramientas y procedimientos para cada

paso (gestión de parches, golden images, IAM, MDM, repositorios y CI/CD si aplica).

- **Actualizar/retroceder a versión segura**
 - Aplicar mitigación del proveedor y actualizar a versión corregida; si no existe, revertir a versión conocida como buena.
 - Verificar firmas/cadena de confianza cuando aplique (code signing).
- **Reimagen/limpieza de sistemas**
 - Reinstalar o reimaginar endpoints/servidores comprometidos; validar persistencia y artefactos.
 - Escanear y limpiar recursos compartidos (servidores de ficheros y almacenamiento cloud) ante malware.
- **Rotación de secretos y endurecimiento**
 - Rotar claves API, tokens OAuth, credenciales de servicio, certificados, contraseñas y secretos de integraciones.
 - Revisar permisos: mínimo privilegio para apps e integraciones; retirar apps no aprobadas.
 - Revisar acceso condicional/MFA para cuentas privilegiadas y de proveedor.
- **Validación post-erradicación**
 - Monitorizar reinfección y actividad anómala (autenticación, cambios admin, exfiltración).
 - Confirmar que no quedan reglas de buzón/reenvíos/automatizaciones sospechosas (si hubo impacto en correo).

Referencia: Recursos de remediación OBJETIVO: Especificar recursos financieros, de personal y logísticos para llevar a cabo la remediación (incluye soporte del proveedor, consultoría IR/forense, y ventanas de mantenimiento).

Comunicar

OBJETIVO: Comunicar con precisión evitando especulación; coordinar con proveedor, Legal y Dirección. Minimizar el daño reputacional y cumplir obligaciones.

OBJETIVO: Especificar herramientas y procedimientos (incluyendo quién participa) o remitir al plan general.

Además de los pasos y orientaciones generales del plan de respuesta a incidentes:

1. Notificar a Dirección y al responsable de seguridad (coordinación de sub-contratas) con resumen: proveedor afectado, impacto probable, acciones de contención.
2. Abrir canal formal con el proveedor (support/CSIRT):
 - Solicitar confirmación de alcance, IOCs, mitigaciones, y evidencia de integridad.

- Solicitar logs/auditorías relacionadas (si están en su control) y calendario de actualizaciones.
3. Coordinar con Legal:
 - Evaluar obligaciones de notificación (clientes, autoridades, aseguradora), especialmente si hay datos personales.
 - Revisar contratos/SLA, y requerimientos de notificación del proveedor.
 4. Coordinar mensajes internos (TIC, Compras, Facturación/Ventas, RRSS/Comunicación, RRHH) con instrucciones claras (“qué hacer / qué no hacer”).
 5. Si web/tienda o RRSS se ven afectados: preparar un comunicado externo breve y verificable (canales oficiales, recomendaciones a clientes).

Recuperación

OBJETIVO: Restaurar servicios con confianza, mejorar controles de proveedores y reducir recurrencia.

OBJETIVO: Especificar herramientas y procedimientos para cada paso (backups, gestión de configuración, hardening, vendor management).

Además de los pasos y orientaciones generales del plan de respuesta a incidentes:

1. Restablecer servicios de forma gradual, priorizando:
 - correo/identidades, CRM/ERP, almacenamiento compartido, web/tienda.
2. Reforzar controles de terceros:
 - Inventario de proveedores críticos y accesos; eliminación de cuentas compartidas.
 - MFA para accesos privilegiados y de proveedores; segmentación/zonas para accesos externos.
 - Revisión de integraciones OAuth/API y permisos mínimos.
3. Mejorar higiene de actualizaciones:
 - Ventanas de mantenimiento, pruebas previas, verificación de firmas, y rollback plan.
 - Mantener inventario de versiones y dependencias (SBOM si aplica) y elevar prácticas de aseguramiento de la cadena de build cuando sea viable.[7]
4. Lecciones aprendidas:
 - Actualizar el registro de riesgos y el proceso de compras/terceros (requisitos de seguridad, notificación y logs).
 - Simulacros y ejercicios con proveedores críticos.

Técnicas MITRE ATT&CK Relevantes en Este Playbook

Cadena de Ataque: Visualización Completa



Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Compromiso de aguas arriba	T1195: Supply Chain Compromise	El atacante compromete un proveedor, un proceso de build, o un artefacto (update/paquete) que después llega a la organización.	Señales del proveedor/CSIRT, discrepancias de hashes/firmas, “updates” fuera de ventana, versiones inesperadas, y correlación con comportamiento anómalo tras una actualización.
Abuso de confianza	T1199: Trusted Relationship	El atacante entra por relaciones de confianza (soporte de proveedor, integraciones, hosting/CDN, cuentas de mantenimiento).	Logs de acceso remoto/RMM/VPN del proveedor, nuevas sesiones fuera de horario, cambios administrativos desde rangos IP del proveedor o infra no habitual, y uso de cuentas compartidas.
Acceso inicial	T1078: Valid Accounts	Uso de cuentas válidas (usuario/servicio/procesador) para entrar en SaaS, VPN, RMM o consola de hosting.	Auditoría de IdP/SSO y plataformas: inicios de sesión desde ubicaciones/dispositivos nuevos, cambios de MFA, tokens recién emitidos, y accesos privilegiados anómalos.
Ejecución	T1059: Command and Scripting Interpreter	Tras la instalación/actualización, el atacante ejecuta comandos o scripts en end-point/servidor.	EDR: árboles de procesos anómalos, ejecución desde rutas de instalación/actualización, scripts invocados por instaladores, y telemetría de PowerShell/bash/python inesperada.

Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Movimiento lateral	T1021: Remote Services	Expansión hacia otros activos (servidores, backoffice, administración, almacenamiento) usando servicios remotos.	Logs de autenticación + red: conexiones RDP/SMB/SSH inusuales, nuevas rutas de administración, y actividad lateral correlacionada tras el evento inicial.
Defensa eva- dida	T1562: Impair Defenses	El atacante desactiva/evita controles (EDR, logging, tamper protection) para persistir o moverse.	Alertas EDR/SIEM por cambios en agentes, servicios detenidos, exclusiones nuevas, políticas alteradas y caída repentina de telemetría.
Acceso a credenciales	T1552: Unsecured Credentials	Robo de secretos en configs, CI/CD, scripts, ficheros <code>.env</code> , o gestores mal configurados.	Detección en repos/CI: accesos a secretos, lectura de ficheros sensibles, accesos a vault/secret manager fuera de patrón, y uso de credenciales de servicio desde hosts no esperados.
Colección	T1213: Data from Information Repositories	Acceso a repositorios (CRM/ERP, almacenamiento cloud, servidor de ficheros, backups, tickets).	CASB/SIEM: descargas masivas, búsquedas/exportaciones inusuales, acceso a múltiples repositorios en poco tiempo, y uso de APIs de export.
Exfiltración	T1041: Exfiltration Over C2 Channel	Extracción de datos mediante canales salientes (HTTPS/APIs) desde endpoints/servidores o SaaS.	Proxy/firewall/CASB: picos de subida, destinos nuevos, patrones de compresión/encryptado, y tráfico a infra recién vista.

Impacto	T1486: Data Encrypted for Impact	Ransomware o cifrado en end-points/servidores tras acceso por proveedor o update.	EDR: actividad de cifrado masivo, eliminación de copias sombra, cambios bruscos en I/O; infraestructura: caídas de servicio y alertas de integridad.
----------------	----------------------------------	---	--

Recursos

Información adicional

1. NIST SP 800-161r1: Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations
2. NIST SP 800-61r2: Computer Security Incident Handling Guide
3. NIST SP 800-218: Secure Software Development Framework (SSDF)
4. CISA: Supply Chain Compromise
5. MITRE ATT&CK: Supply Chain Compromise (T1195)
6. ENISA: Threat Landscape (secciones de supply chain)
7. SLSA: Supply-chain Levels for Software Artifacts
8. OWASP: Software Supply Chain Security
9. CNCF: Software Supply Chain Best Practices
10. INCIBE: recursos y avisos
11. CCN-CERT: guías y recursos (España)

Playbook: Acceso No Autorizado

Investigar, remediar (contener, erradicar) y comunicar en paralelo.

Asigne pasos a individuos o equipos para que trabajen simultáneamente, cuando sea posible; este libro de jugadas no es puramente secuencial. Utilice su mejor criterio.

Cadena de Ataque

Attack Chain: Acceso No Autorizado

Figure 1: Attack Chain: Acceso No Autorizado

Investigar

OBJETIVO: Confirmar que se trata de un acceso no autorizado real (descartar falsos positivos), identificar el vector de entrada, el alcance del acceso y los datos o sistemas comprometidos.

MITRE ATT&CK Navigator – Acceso No Autorizado

Figure 2: MITRE ATT&CK Navigator – Acceso No Autorizado

1. Triage rápido (primeras 1–2 horas)

- Confirmar la alerta: verificar si el acceso detectado es realmente no autorizado (descartar accesos legítimos, cambios de turno, cuentas de servicio, accesos remotos autorizados).
- Identificar el tipo de acceso:
 - Acceso físico no autorizado (instalaciones, CPD, hardware).
 - Acceso lógico remoto (RDP, VPN, SSH, acceso web/portal).
 - Acceso interno (empleado con permisos excesivos o cuenta comprometida).
 - Acceso a sistemas en la nube o SaaS (panel de administración, consola cloud, correo, almacenamiento).
 - Acceso a través de cuenta de tercero o proveedor.
- Capturar evidencia mínima sin modificar sistemas:
 - Logs de autenticación (IPs, timestamps, agente de usuario, geolocalización).
 - Nombre de usuario/cuenta, sistemas accedidos, duración de la sesión.
 - Alertas de herramientas (SIEM, EDR, IAM, CASB, WAF).
 - Capturas de pantalla o exportaciones de logs relevantes.

2. Determinar el vector de acceso

- Revisar los vectores de acceso inicial más comunes (MITRE ATT&CK TA0001):
 - Credenciales robadas o filtradas (phishing, credential stuffing, brute force, compra en dark web).
 - Sesión secuestrada (session hijacking, cookie theft, token robado).
 - Explotación de vulnerabilidad (servicio expuesto sin parchear: VPN, RDP, aplicación web).
 - Cuenta de proveedor/tercero comprometida.
 - Insider: empleado con acceso legítimo que actúa fuera de su ámbito.
 - Bypass de MFA (SIM swapping, MFA fatigue, phishing de OTP en tiempo real).
- Cruzar la hora del acceso con:
 - Tickets de soporte o cambios recientes relacionados con la cuenta.
 - Alertas de phishing o malware previas.
 - Intentos fallidos de autenticación previos al acceso exitoso.

3. Dimensionar el alcance

- Identificar todos los sistemas, datos y cuentas a los que se accedió o que podrían haberse visto expuestos:
 - Sistemas internos (servidores, endpoints, bases de datos, directorio activo).

- Servicios en la nube (almacenamiento, correo, CRM/ERP, repositorios).
 - Datos sensibles: PII, datos financieros, propiedad intelectual, datos de clientes.
 - Determinar si el atacante realizó alguna de las siguientes acciones:
 - Descarga o exfiltración de datos (volumen, tipos de fichero, destinos).
 - Modificación o borrado de información.
 - Creación de nuevas cuentas o cambios de permisos.
 - Instalación de software, backdoors o mecanismos de persistencia.
 - Reconocimiento interno (escaneos, consultas al directorio, enumeración de recursos).
 - Revisar logs de:
 - EDR/AV: procesos lanzados, conexiones, cambios en el sistema.
 - SIEM: correlación de eventos de autenticación, acceso a datos y cambios de configuración.
 - Proxy/Firewall/DNS: conexiones salientes sospechosas, exfiltración.
 - SaaS audit logs: accesos, descargas, cambios de configuración, creación de reglas.
4. **Determinar el alcance en datos (qué información puede haberse expuesto)**
- Identificar los repositorios accesibles desde la cuenta o sistema comprometido.
 - Estimar si hubo acceso, copia o exfiltración de:
 - Datos personales de clientes, empleados o proveedores (PII/datos especialmente protegidos).
 - Información financiera o bancaria.
 - Credenciales de otros sistemas (password stores, secretos de CI/CD, etc.).
 - Propiedad intelectual, contratos o documentación confidencial.
 - Determinar si aplican obligaciones legales de notificación (RGPD, normativa sectorial).
5. **Evaluar el impacto y priorizar**
- Priorizar según: tipo de datos expuestos, número de sistemas/usuarios afectados, riesgo de movimiento lateral, impacto financiero/reputacional y obligaciones regulatorias.
 - Escalar a Dirección y Legal si hay indicios de exfiltración de datos personales o impacto significativo.

alt text

Figure 3: alt text

Diagrama de Flujo: Playbook de Acceso No Autorizado

Remediar

Flujo de Respuesta – Acceso No Autorizado

Figure 4: Flujo de Respuesta – Acceso No Autorizado

- **Planificar eventos de remediación** en los que estos pasos se lancen juntos (o de forma coordinada), con los equipos apropiados listos para responder a cualquier interrupción.
- **Considere el momento y las compensaciones** de las acciones de remediación: su respuesta tiene consecuencias.

Contención OBJETIVO: Detener el acceso no autorizado activo, reducir la superficie de exposición y evitar el movimiento lateral, sin destruir evidencia.

OBJETIVO: Especificar herramientas y procedimientos internos para cada paso (IAM, EDR, SIEM, proxy/firewall, MDM).

- **Bloquear o deshabilitar la cuenta comprometida**
 - Deshabilitar o suspender de inmediato la cuenta de usuario o de servicio implicada.
 - Invalidar todas las sesiones activas, tokens OAuth, cookies y tokens de API asociados.
 - Si es una cuenta de proveedor: deshabilitar el acceso y notificar al proveedor.
- **Rotar credenciales de forma urgente**
 - Forzar el restablecimiento de contraseña en la cuenta comprometida y en cuentas relacionadas.
 - Revocar y rotar claves API, secretos de servicio y certificados asociados.
 - Si se sospecha reutilización de contraseñas: iniciar rotación en otros sistemas críticos.
- **Aislar sistemas afectados si se detectó movimiento lateral o persistencia**
 - Aislar de red los endpoints o servidores comprometidos.
 - Restringir acceso administrativo en sistemas críticos hasta confirmar el alcance.
- **Bloquear el vector de acceso**
 - Bloquear IPs, ASNs o rangos de origen identificados en firewall/WAF.
 - Si el vector es una vulnerabilidad: aplicar mitigación temporal (WAF rule, desactivar servicio vulnerable) hasta parchar.
 - Si el vector es una integración OAuth/API: revocar la app o el permiso.

- **Activar vigilancia reforzada**
 - Añadir reglas de detección en SIEM/EDR para la cuenta, IP o patrón identificado.
 - Activar alertas de umbral bajo para autenticación, acceso a datos sensibles y cambios de privilegios.
- **Retención forense**
 - Exportar y preservar todos los logs relevantes (autenticación, acceso a datos, actividad de red) antes de que expiren.
 - No modificar ni borrar sistemas comprometidos hasta completar la recogida de evidencias.

OBJETIVO: Considerar la automatización de medidas de contención mediante herramientas de orquestación (SOAR) donde exista.

Erradicar OBJETIVO: Eliminar cualquier mecanismo de persistencia, cerrar el vector de entrada y restaurar un estado de confianza verificado.

OBJETIVO: Especificar herramientas y procedimientos para cada paso (gestión de parches, IAM, EDR, golden images).

- **Eliminar persistencia**
 - Buscar y eliminar backdoors, tareas programadas, scripts de inicio, cuentas ocultas o claves SSH no autorizadas.
 - Revisar reglas de reenvío de correo, reglas de buzón y delegaciones creadas durante el incidente.
 - Comprobar cambios en grupos de seguridad, roles IAM y permisos en la nube.
- **Parchear o mitigar el vector de acceso**
 - Aplicar el parche de seguridad correspondiente si el vector fue una vulnerabilidad.
 - Revisar y endurecer la configuración del servicio expuesto (desactivar funciones innecesarias, reducir superficie).
- **Reimagen o reinstalación si hay indicios de compromiso profundo**
 - Reinstalar o reimaginar endpoints/servidores donde se detectó actividad maliciosa.
 - Restaurar desde backup limpio y verificado si se modificaron datos o configuraciones.
- **Revisión y endurecimiento de identidades**
 - Auditar todas las cuentas con privilegios elevados: eliminar las que no sean necesarias.
 - Revisar y aplicar principio de mínimo privilegio en cuentas, roles e integraciones.
 - Asegurar que MFA está habilitado en todas las cuentas críticas, especialmente administradores y accesos remotos.
- **Validación post-erradicación**

- Monitorizar reinfección, nuevos accesos anómalos y actividad de reconocimiento durante al menos 72 horas.
- Confirmar que no quedan sesiones activas, tokens válidos ni backdoors en sistemas remediados.

Referencia: Recursos de remediación **OBJETIVO:** Especificar recursos financieros, de personal y logísticos para llevar a cabo la remediación (incluye soporte forense externo, ventanas de mantenimiento y comunicación con proveedores).

Comunicar

OBJETIVO: Comunicar con precisión, evitando especulación; coordinar con Legal, Dirección y, si aplica, autoridades y afectados. Cumplir con las obligaciones regulatorias.

OBJETIVO: Especificar herramientas y procedimientos (incluyendo quién participa) o remitir al plan general.

Además de los pasos y orientaciones generales del plan de respuesta a incidentes:

1. Notificar a Dirección y al responsable de seguridad con resumen inicial: qué cuenta/sistema fue accedido, cuándo, qué datos podrían haberse expuesto, y qué medidas de contención se han tomado.
 2. Coordinar con Legal:
 - Evaluar obligaciones de notificación a autoridades (AEPD u organismo equivalente) en un plazo máximo de 72 horas si hay datos personales afectados (RGPD Art. 33).
 - Evaluar obligación de notificación a los interesados (RGPD Art. 34) si el riesgo para sus derechos es alto.
 - Revisar contratos con proveedores si el vector implicó a un tercero.
 - Notificar a la aseguradora si aplica la póliza de ciberriesgo.
 3. Notificar internamente a los departamentos afectados (TIC, RRHH si hay cuentas de empleados, Finanzas si hay datos financieros, Comunicación).
 4. Si hay clientes o usuarios afectados: preparar comunicado externo claro, conciso y verificable a través de canales oficiales, con instrucciones de actuación (cambio de contraseña, vigilancia de actividad, etc.).
 5. Si el acceso fue realizado por un empleado o insider: coordinar con RRHH y Asesoría Jurídica antes de cualquier comunicación o acción disciplinaria.
-

Recuperación

OBJETIVO: Restaurar el servicio con confianza, mejorar controles de acceso e identidad, y reducir la probabilidad de recurrencia.

OBJETIVO: Especificar herramientas y procedimientos para cada paso (IAM, backups, gestión de parches, formación).

Además de los pasos y orientaciones generales del plan de respuesta a incidentes:

1. Restablecer el acceso de la cuenta afectada (si procede) solo tras verificar la identidad del usuario, rotar credenciales y confirmar la ausencia de persistencia.
2. Reforzar controles de identidad y acceso:
 - MFA obligatorio en todos los accesos remotos, cuentas privilegiadas y aplicaciones críticas.
 - Revisión y reducción de permisos excesivos (access review periódico).
 - Desactivar cuentas inactivas y de exempleados.
 - Segmentación de red y acceso condicional (Zero Trust donde sea viable).
3. Mejorar la visibilidad y detección:
 - Revisar cobertura de logs y alertas de autenticación en todos los sistemas críticos.
 - Implementar o mejorar alertas de comportamiento anómalo (accesos fuera de horario, desde ubicaciones inusuales, volumen elevado de descargas).
4. Formación y concienciación:
 - Reforzar la formación en phishing y gestión segura de credenciales para todos los empleados.
 - Comunicar el incidente (de forma anónima si es necesario) como caso de aprendizaje interno.
5. Lecciones aprendidas:
 - Documentar la cronología completa, el vector de acceso, el impacto y las acciones realizadas.
 - Actualizar el registro de riesgos, los procedimientos de gestión de accesos y el plan de respuesta a incidentes.
 - Revisar controles técnicos: parcheo, gestión de vulnerabilidades, rotación periódica de credenciales.

Referencia: Acciones del usuario ante la sospecha de acceso no autorizado a su cuenta

OBJETIVO: Personalizar los pasos para usuarios que sospechen que su cuenta ha sido accedida sin autorización.

1. Mantenga la calma. No cierre sesión ni modifique nada hasta recibir instrucciones.
2. Haga fotos o capturas de pantalla de cualquier actividad sospechosa que haya observado.
3. Tome nota de: qué detectó, cuándo, desde qué dispositivo y red, y con quién ha hablado sobre ello.

4. Contacte al servicio de soporte o al responsable de seguridad de inmediato y sea lo más descriptivo posible.
 5. No comparta su contraseña ni otros datos de acceso con nadie, ni siquiera con el equipo de soporte (ellos no la necesitan).
 6. Tenga paciencia: la respuesta puede implicar restricciones temporales, pero es para proteger a todos. **Gracias por avisar.**
-

Referencia: Acciones del servicio de asistencia técnica ante la sospecha de acceso no autorizado

OBJETIVO: Personalizar los pasos para el personal del helpdesk ante la sospecha de acceso no autorizado.

1. Mantenga la calma y abra un ticket documentando el incidente.
 2. Recopile la siguiente información del usuario o de los sistemas de monitorización:
 - ¿Qué actividad sospechosa se ha detectado y cuándo?
 - ¿Qué cuenta(s) y sistema(s) están implicados?
 - ¿Desde qué IP, dispositivo o ubicación geográfica se produjo el acceso?
 - ¿Ha habido intentos fallidos previos de autenticación?
 - ¿Ha recibido el usuario algún correo sospechoso recientemente?
 3. No restablezca contraseñas ni deshabilite cuentas sin coordinación con el equipo de seguridad.
 4. Preserve los logs: no borrar ni modificar registros de autenticación o acceso.
 5. Escale al equipo de seguridad de inmediato con toda la información recopilada.
 6. Siga las instrucciones del equipo de seguridad para las acciones de contención.
-

Recursos

Información adicional

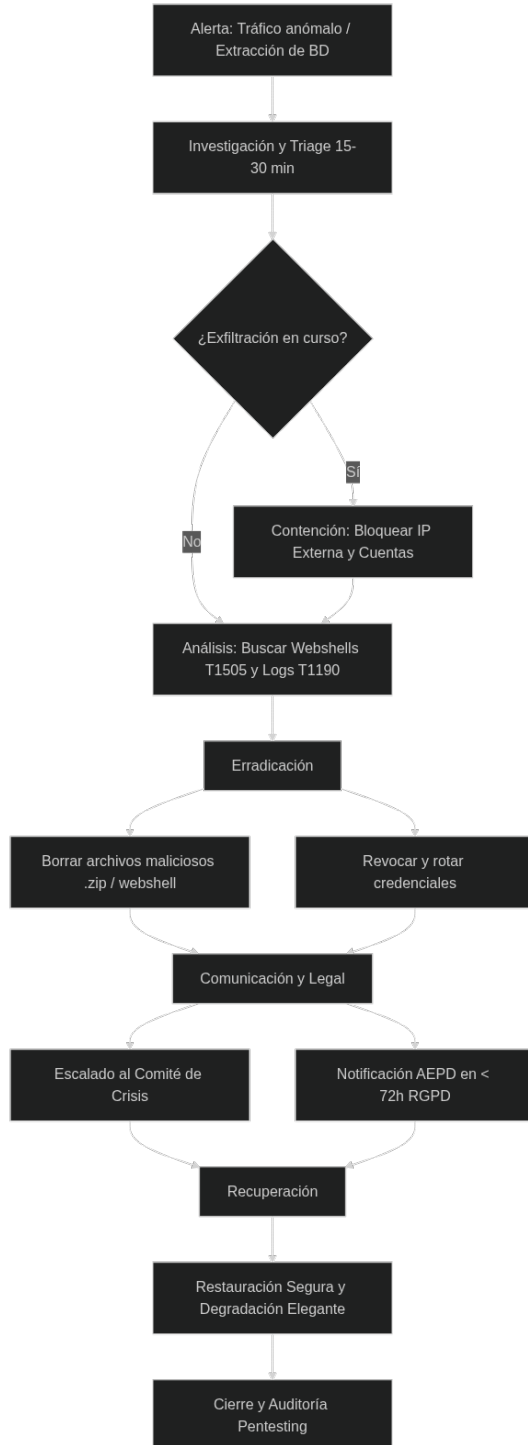
1. MITRE ATT&CK: Initial Access (TA0001)
2. MITRE ATT&CK: Credential Access (TA0006)
3. NIST SP 800-61r2: Computer Security Incident Handling Guide
4. NIST SP 800-63B: Digital Identity Guidelines – Authentication
5. CISA: Implementing Phishing-Resistant MFA
6. ENISA: Guidelines for SMEs on the Security of Personal Data Processing
7. AEPD: Guía para la notificación de brechas de datos personales
8. INCIBE: Gestión de incidentes de seguridad
9. CCN-CERT: Guía de seguridad CCN-STIC – Gestión de identidades y accesos

10. OWASP: Authentication Cheat Sheet # Playbook: Exfiltración de Datos
(Web/Tienda Online)

Cuando detectamos que datos están siendo extraídos de nuestro sistema, cada minuto cuenta. Este playbook te guía a través de los pasos necesarios para **investigar qué pasó, contener el daño y comunicar** de forma transparente.

Lo más importante: no hagas todo de forma secuencial. El equipo de seguridad investiga mientras el equipo de sistemas contiene el acceso; mientras tanto, Legal se prepara para notificar. Trabaja en paralelo cuando sea posible.

Diagrama de Flujo del Incidente



1. Investigar

Lo primero es saber qué pasó y qué tan malo es. En los primeros 15–30 minutos necesitas responder tres preguntas fundamentales: ¿siguen saliendo datos ahora mismo?, ¿cómo entraron?, ¿qué información se fue?

Los Primeros 15–30 Minutos (Acciones Inmediatas)

¿Están sacando datos en este momento? Lo primero es confirmar que el ataque está ocurriendo. Busca picos anómalos de tráfico de salida desde el servidor web hacia direcciones IP desconocidas. Si el ataque está en marcha, tienes que cortarlo ya.

¿Cómo entraron? Habitualmente es por una vulnerabilidad en la aplicación web misma (algo que el proveedor no ha parcheado) o por credenciales débiles/reutilizadas. Este tipo de entrada la rastrean en MITRE ATT&CK como **Exploit Public-Facing Application** (T1190) — significa que simplemente usaron una vulnerabilidad conocida en tu aplicación web.

Acciones concretas ahora:

1. Pide al equipo de sistemas que extraiga los logs de acceso del servidor web y del WAF (Web Application Firewall). Estos logs son volátiles en infraestructuras en la nube; si no los guardas ahora, desaparecerán. Cópielos a un almacenamiento seguro local.
2. Documenta las direcciones IP desde las que se está extrayendo el tráfico y hacia dónde va. Apunta todo: direcciones IP, puertos, protocolos.
3. Nombra un responsable de investigación (analista SOC o equivalente) y un responsable de contención (ingeniero de red/sistemas). Estos dos van a trabajar en paralelo.
4. Si hay datos de clientes implicados, avisa ya al equipo legal. Aquí estamos hablando de notificación obligatoria a la AEPD dentro de 72 horas.

Entendiendo Qué Fue Comprometido

Una vez que has parado el sangrado inmediato, necesitas entender qué se llevaron exactamente.

Preguntas clave:

- ¿Fueron solo datos de catálogo (productos, descripciones) o también información de clientes (nombres, emails, direcciones)?
- ¿Accedieron a datos financieros? (números de tarjeta, cuentas bancarias)
- ¿Está comprometida solo la tienda online o también otros sistemas?

Para responder esto, busca patrones en los logs:

- Conexiones SSH/FTP raras hacia servidores externos. Los atacantes a veces copian datos usando herramientas estándar, así que verás intentos de conectar a máquinas que no son nuestras.
 - Archivos `.zip` o `.tar.gz` grandes que aparecieron de repente en directorios públicos del servidor. Los atacantes suelen comprimir la base de datos antes de llevarla. En MITRE ATT&CK esto se cataloga como **Archive Collected Data** (T1560).
 - Volcados SQL o consultas masivas en los logs de la base de datos. Si ves consultas como `SELECT * FROM customers;` saliendo de IP externas, sabes que alguien está robando datos de forma automatizada.
-

Buscando el Punto de Entrada

Aquí es donde investigas cómo el atacante llegó hasta donde llegó. Típicamente:

1. Encontró una vulnerabilidad en tu aplicación web o en una de sus dependencias (WordPress, PrestaShop, un plugin específico).
2. Explotó esa vulnerabilidad para ejecutar código en el servidor.
3. Leyó archivos de configuración (`.env`, `wp-config.php`) que contenían credenciales de la base de datos en texto plano. Esto es lo que MITRE ATT&CK llama **Unsecured Credentials** (T1552.001) — simplemente credenciales que cualquiera puede leer si accede al servidor.
4. Con esas credenciales, se conectó a la base de datos directamente y volcó todo.

Busca en el servidor:

- Scripts PHP/JSP/ASP que fueron creados recientemente y que no reconoces. Los atacantes muchas veces dejan una “puerta trasera” (MITRE ATT&CK: **Web Shell**, T1505.003) para poder volver más tarde sin tener que explotar la vulnerabilidad de nuevo.
 - En los logs de aplicación web, busca intentos de subida de archivos o cambios de permisos. Si ves algo como `PUT /shell.php` o `POST /admin/upload`, eso es un red flag.
-

La Gravedad del Incidente

Este incidente es **CRÍTICO** por definición. Aquí está por qué:

- Los datos personales y financieros de tus clientes han salido de tu control.
- Tienes una obligación legal (RGPD) de notificar a cada cliente afectado.
- Tienes que notificar a la AEPD en 72 horas.
- Tus clientes (autónomos y pymes) pueden sufrir fraude o robo de identidad basado en esta información.

- Puedes ser víctima de extorsión: el atacante puede amenazar con publicar los datos si no pagas.

Esto requiere **escalado inmediato al Comité de Crisis** (CISO, CEO, Legal, Comunicación).

2. Remediar: Contener, Erradicar y Recuperar

Una vez que sabes qué pasó, necesitas hacer tres cosas:

1. **Contener:** Detener el daño inmediatamente. Si los atacantes todavía tienen acceso, córtalo ya.
2. **Erradicar:** Eliminar cualquier herramienta o acceso que dejaron los atacantes para no volver.
3. **Recuperar:** Levantar los servicios de forma segura.

Contención: Frenar la Salida de Datos

La prioridad número uno es cerrar el grifo. Si los datos todavía se están filtrando, esto es lo que haces:

Bloquear el acceso externo. Identifica la dirección IP desde la que el atacante se está conectando y bloquéala en el firewall perimetral y en el WAF. Esta acción debería tardar minutos, no horas. Es una “regla drop” simple.

Revoca los accesos comprometidos. Si sabes que el atacante usó credenciales de la base de datos, cambia esas contraseñas ya. Desactiva cualquier cuenta de usuario o servicio que haya sido comprometida. En MITRE ATT&CK esto se llama **Revoke Authentication Credentials** (T3002) — simplemente dejar inutilizable lo que el atacante estaba usando.

Aísla la infraestructura de la web hacia la sede central. Si tu tienda online está conectada a tu red interna mediante una VPN site-to-site, desconéctala temporalmente. El atacante no debería poder saltar desde el servidor web hacia tus sistemas internos. Puedes reconectar cuando hayas limpiado todo.

Nota importante: Coordina esto con dirección. Desconectar la tienda online significa que deja de funcionar. Es una decisión que tiene impacto inmediato en ventas. Pero si estamos ante una exfiltración activa, el impacto de reputación de dejar la tienda comprometida es mucho mayor.

Erradicación: Limpiar el Entorno

El atacante probablemente dejó una o varias “puertas traseras” para poder volver. Tienes que encontrarlas y eliminarlas.

Busca y elimina web shells. Las web shells son scripts (PHP, JSP, ASP) que el atacante sube al servidor para ejecutar código remotamente. Busca en el servidor archivos con extensiones sospechosas que fueron creados recientemente y que no reconoces. Los nombres típicos son cosas como `admin.php`, `shell.php`, `test.jsp`. Elimínalos. En MITRE ATT&CK esto es **Remove Files** (T1070.004).

Busca y elimina archivos de volcado. Si el atacante creó archivos ZIP o TAR de la base de datos antes de llevarlos, sigue habiendo copias en tu servidor. Busca en `/tmp`, en directorios públicos del servidor web, en cualquier lugar donde haya archivos grandes creados recientemente. Elimínalos.

Revisa la configuración de la aplicación. El atacante pudo haber dejado puertas traseras a nivel de aplicación: usuarios administrativos ocultos, tokens de API, claves SSH en archivos que no deberían tenerlas. Revisa archivos de configuración (`.env`, `wp-config.php`, `config.php`) y comprueba que: - No hay credenciales en texto plano - No hay claves SSH compartidas - No hay tokens de API obsoletos

Aplica parches de seguridad. La vulnerabilidad que permitió que el atacante entrara sigue ahí si no la fixes. Aplica el parche de seguridad para la vulnerabilidad específica (WordPress, PrestaShop, el framework que uses) que fue explotada. Si no sabes cuál fue exactamente, coordina con el proveedor externo para que los aplique todos.

Recuperación: Volver a Poner Todo en Marcha

Aquí es donde intentas que todo funcione de nuevo, pero de forma segura.

Restaura desde un backup. Si tienes un backup del servidor anterior al incidente, ese es tu punto de referencia para la recuperación. Idealmente, ese backup debería ser inmutable (no puedes modificarlo una vez creado) para que el atacante no lo haya comprometido también.

Levanta la web en modo degradado primero. No reconectes todo de golpe. Pon la web inicialmente en modo “solo lectura” o en una página de mantenimiento. De esa forma puedes validar que los cambios de seguridad que hiciste funcionan sin exponer los servicios de pago o datos de clientes.

Conecta la base de datos con cuidado. Una vez que hayas validado que el servidor web está limpio, reconecta la base de datos. Pero antes: - Verifica que las credenciales que pusiste son nuevas (no las comprometidas). - Checkea que los permisos de base de datos son los mínimos necesarios (no permiso total). - Activa logs de acceso a la base de datos para poder detectar cualquier cosa rara de aquí en adelante.

Habilita un WAF fuerte. Antes de abrir el servicio completamente, asegúrate de que tienes un WAF (Web Application Firewall) configurado estrictamente.

Debería bloquear: - Intentos de subida de archivos PHP/JSP en directorios inesperados. - Consultas SQL que parezcan intentos de inyección. - Patrones de ataque web conocidos.

Activa monitorización. Desde este momento en adelante, cada petición a la web debería generar una alerta si parece sospechosa. Conecta los logs del servidor web y de la base de datos a tu SIEM (Security Information and Event Management). Si el atacante intenta volver, quieres saberlo lo antes posible.

3. Comunicar

No es suficiente con arreglarlo; tienes que decirle a la gente qué pasó. Y tienes que hacerlo dentro de plazos legales y de forma transparente.

Los Primeros 72 Horas: La Notificación Regulatoria

Si has confirmado que se fugaron datos personales de clientes, tienes un plazo máximo de 72 horas para notificar a la Agencia Española de Protección de Datos (AEPD). No es una recomendación, es una obligación legal bajo el RGPD. Si no lo haces, las multas van desde los 10 millones hasta los 20 millones de euros (o el 4% de tu facturación anual, lo que sea mayor). En una empresa de 150 personas, eso probablemente signifique quiebra.

¿Qué significa notificar a la AEPD? Tienes que presentar un informe que detalle: - Qué datos se fugaron exactamente (nombres, emails, números de cuentas bancarias, etc.) - Cuándo descubriste que se habían fugado - Qué medidas de seguridad tenías - Qué medidas estás tomando ahora para evitar que vuelva a pasar - Qué riesgos corre cada persona cuyos datos se fugaron

Este informe lo prepara el equipo legal con ayuda del equipo de seguridad. No es algo que puedas demorar.

Elevar a Dirección: El Comité de Crisis

Este tipo de incidente requiere que toda la dirección se entere. Tienes que abrir una reunión de crisis con:

- **CISO** (Chief Information Security Officer): Lidera la respuesta técnica.
- **CEO/Dirección General**: Necesita saber el impacto empresarial y las decisiones que se van a tomar.
- **Legal**: Prepara la notificación a la AEPD, gestiona temas de responsabilidad civil.
- **Comunicación/PR**: Prepara el mensaje para clientes y prensa.

En esta reunión se decide si la tienda va a estar fuera de servicio, cuándo se levanta, qué se comunica a clientes.

Comunicación a Clientes Afectados

Una vez que has notificado a la AEPD, tienes que comunicar a cada cliente cuyos datos se fugaron. Y tienes que hacerlo de forma clara y sin intentar esconder nada. Aquí está lo que tienes que incluir:

¿Qué pasó? Un párrafo claro: “Detectamos que los datos de nuestros clientes fueron accedidos sin autorización a través de una vulnerabilidad en nuestro servidor web. Hemos identificado qué información fue afectada y qué medidas estamos tomando.”

¿Qué datos se fugaron? Sé específico. “Se fugaron nombres, emails, y direcciones de facturación” es mejor que “información de cuenta”. Los clientes necesitan saber si su número de tarjeta está en peligro o si es “solo” dirección de email.

¿Qué riesgo corren? Sé honesto. Si se fugaron números de tarjeta, los clientes deben estar atentos a fraude. Si fue dirección de email, pueden esperar phishing. Si fue información de cuenta bancaria, la amenaza es mayor.

¿Qué deben hacer? Dale acciones concretas: - Cambiar la contraseña en tu plataforma. - Vigilar su estado de cuenta bancaria durante los próximos meses. - Activar alertas de fraude con sus bancos si disponen de ello. - Contactar con un número de teléfono o email si tienen preguntas.

¿Qué estamos haciendo nosotros? Detalla: - Hemos cerrado el servidor comprometido. - Hemos parcheado la vulnerabilidad. - Hemos activado un WAF más estricto. - Vamos a hacer una auditoría de seguridad externa.

Comunicación a los medios: Si el incidente es suficientemente grave, aparecerá en prensa. Es mejor que lo comuniques tú de forma controlada que dejar que salga en un titular sensacionalista. Un comunicado de prensa claro y transparente es tu mejor defensa reputacional en este momento.

Coordinación con el Proveedor Externo

El servidor web está en las manos de tu proveedor de hosting. Tienes que exigirle:

1. **Un informe detallado:** Acceso físico y lógico a los servidores. ¿Quién accedió cuándo? ¿Se tocó algo en el hipervisor?
2. **Logs completados:** Asegúrate de que tienes copias de TODOS los logs (acceso, aplicación, sistema) desde antes del incidente.
3. **Auditoría externa:** El proveedor debería encargarse de una auditoría de seguridad para entender cómo pasó esto.

4. **Garantías de seguridad:** Asegúrate de que el proveedor tiene un plan para evitar que esto vuelva a pasar. Si no lo tiene claro, plantéate cambiar de proveedor.
-

4. Recuperación y Lecciones Aprendidas

Una vez que el incidente está “controlado”, necesitas reconstruir con una mentalidad diferente: la de evitar que vuelva a pasar.

Restauración del Servicio

El plan de vuelta a la normalidad: No abras la tienda de repente. Levanta el servicio en fases:

1. Servidor web limpio + base de datos restaurada + sin conexión a sistemas internos. Solo para que técnicos lo validen.
2. Servidor web limpio + base de datos + pasarela de pagos desactivada. La web funciona pero no se venden cosas (modo lectura).
3. Servidor web limpio + base de datos + pasarela de pagos activada + WAF estricto + monitorización máxima. Ya funciona normalmente pero con todas las alarmas puestas.

Cada fase requiere validación. Si algo huele mal, no avances a la siguiente.

Medidas de Seguridad a Largo Plazo

Este incidente te enseña que confiar en tu proveedor externo “porque es experto” no es suficiente. Necesitas:

WAF permanente y estricto. Un Web Application Firewall debería estar en frente de tu tienda online de aquí en adelante. No es opcional. Debería bloquear patrones conocidos de ataque y alertarte de cosas raras.

Auditoría de seguridad trimestral. Paga a una empresa externa para que penetre tu tienda online buscando vulnerabilidades. Si encuentran algo, arréglalo antes de que un atacante lo encuentre.

Monitorización 24/7. Los logs de tu servidor web y base de datos deberían fluir a un SIEM (herramienta de monitorización). Si el atacante intenta volver, lo sabrás en tiempo real.

Gestión de credenciales. Jamás dejes contraseñas en archivos de configuración. Usa un gestor de secretos (Vault, AWS Secrets Manager, etc.) donde las credenciales están encriptadas y se rotan regularmente.

Actualizaciones automáticas. Tu CMS, plugins y dependencias deberían actualizarse automáticamente cuando hay parches de seguridad. No esperes a hacerlo manualmente.

Lecciones Aprendidas

Después de que todo está estabilizado, reúnete con el equipo y pregunta:

¿Por qué pasó esto? Típicamente por una combinación de: - Vulnerabilidad sin parchear en la aplicación web. - Credenciales en texto plano en archivos de configuración. - Falta de segmentación de red (el servidor web podía conectarse a sistemas internos). - Falta de monitorización que detectara la anomalía más rápido.

¿Qué vamos a cambiar? Haz un plan concreto: - Cambiar de proveedor si no tienen estándares de seguridad. - Implementar un WAF si no lo tienes. - Cambiar los procesos de parcheo para hacerlos más rápidos. - Entrenar al equipo en desarrollo seguro (OWASP, manejo de secrets, etc).

¿Qué tiempo perdimos en qué? Analiza dónde se fue el tiempo: - ¿Cuánto tardaste en detectar el incidente? - ¿Cuánto en entender qué pasó? - ¿Cuánto en contenerlo? - ¿Cuánto en comunicar?

Cada una de estas fases es donde puedes mejorar para la próxima vez (esperamos que no la haya, pero si la hay, estarás más preparado).

Recordatorios Prácticos

Antes de que nadie reinicie o apague nada: Los logs son la evidencia. En una infraestructura en la nube, los logs desaparecen rápido. Extrae y guarda los logs de acceso web, logs de base de datos, logs de firewall, y cualquier cosa que tenga timestamp **antes** de tocar nada. La cadena de custodia (probar que la evidencia no fue alterada) es crucial si esto acaba en procedimientos legales o regulatorios.

No hagas nada en paralelo sin coordinación. Si un técnico está restaurando un backup mientras otro está intentando parchar la vulnerabilidad, pueden pisarse los cambios. Tienes que tener un único “líder técnico” que coordina quién hace qué.

Documenta todo mientras lo haces. No esperes a que termine el incidente para escribir un informe. Apunta en tiempo real: - Qué encontraste - Qué hiciste - A qué hora - Quién lo validó

Esto hace que el informe final sea mucho más fácil de escribir y que no pierdas detalles importantes.

Técnicas MITRE ATT&CK Relevantes en Este Playbook

Cadena de Ataque: Visualización Completa

Attack Chain

Figure 5: Attack Chain

Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Explotación	T1190: Exploit Public-Facing Application	El atacante encuentra una vulnerabilidad en tu aplicación web (WordPress, PrestaShop, plugin, etc.) y la explota para ejecutar código.	Busca en los logs de acceso peticiones HTTP inusuales, errores 200 OK después de patrones de fuzzing, o POST requests a archivos que no deberían recibir input.
Acceso a Credenciales	T1552.001: Unsecured Credentials	El atacante lee archivos de configuración (<code>.env</code> , <code>wp-config.php</code>) que contienen credenciales de base de datos en texto plano.	Revisa si tus archivos de configuración están en directorios accesibles públicamente o están siendo leídos por el servidor web.

Fase	Técnica MITRE	Descripción	Cómo la Detectamos
Creación de Puerta Trasera	T1505.003: Web Shell	El atacante deja un script (PHP, JSP, ASP) en el servidor para poder volver más tarde sin necesidad de re-explotar la vulnerabilidad.	Busca archivos PHP/JSP creados recientemente en directorios públicos, o cambios en ficheros de configuración de servidor web.
Compresión de Datos	T1560: Archive Collected Data	El atacante comprime la base de datos en un archivo .zip o .tar.gz antes de extraerlo.	Busca archivos grandes de compresión creados recientemente, especialmente en directorios públicos o /tmp .
Exfiltración	T1048: Exfiltration Over Alternative Protocol	El atacante extrae los datos usando HTTP, FTP, DNS, o cualquier protocolo que tenga permitido salir por el firewall.	Monitoriza el tráfico de salida anómalo, conexiones FTP/SFTP a IPs externas, o patrones DNS inusuales.

alt text

Figure 6: alt text

Visualización Interactiva con React

Si tu organización quiere un dashboard interactivo en tiempo real para monitorizar el estado del incidente y las técnicas MITRE ATT&CK detectadas, puedes construir una interfaz con **React** que:

- **Muestre la cadena de ataque en vivo** — cada técnica detectada se ilumina en el diagrama
- **Actualice en tiempo real** — integrado con tu SIEM o herramienta de logs
- **Sea colaborativo** — todos los equipos (SOC, sistemas, legal) ven el mismo estado
- **Mappe automáticamente** — relaciona alertas de tu plataforma con técnicas MITRE ATT&CK

Esta integración es especialmente valiosa durante el incidente porque permite que: 1. El equipo técnico vea qué técnicas se están usando 2. El Comité de Crisis vea el progreso en tiempo real 3. Legal sepa exactamente cuándo se detectó cada cosa (para cadena de custodia)

alt text

Recursos y Referencias

- **AEPD (Agencia Española de Protección de Datos)**: Guía de notificación de brechas — todo sobre cómo notificar correctamente.
- **MITRE ATT&CK Framework**: T1190 (Exploit Public-Facing Application) — la técnica inicial típica en este tipo de ataques.
- **INCIBE**: Gestión de incidentes de ciberseguridad — guía práctica en español sobre respuesta a incidentes.
- **OWASP Top 10**: Ten esto en cuenta para el desarrollo seguro de tu aplicación web.
- **RE&CT Framework**: Acciones de respuesta estructuradas (RE&CT = Responder, Response Actions). **## Playbook**: Pérdida o Robo de Dispositivo

Investigar, remediar (contener, erradicar) y comunicar en paralelo.

Asigne pasos a individuos o equipos para que trabajen simultáneamente, cuando sea posible; este libro de jugadas no es puramente secuencial. Utilice su mejor criterio.

Cadena de Ataque

Attack Chain: Pérdida o Robo de Dispositivo

Figure 7: Attack Chain: Pérdida o Robo de Dispositivo

Investigar

MITRE ATT&CK Navigator – Pérdida o Robo de Dispositivo

Figure 8: MITRE ATT&CK Navigator – Pérdida o Robo de Dispositivo

OBJETIVO: Confirmar que el dispositivo ha sido perdido o robado (descartar extravíos temporales), identificar qué datos y sistemas podrían estar expuestos, y evaluar el riesgo real según el estado del dispositivo.

1. Triage rápido (primeras 1–2 horas)

- Confirmar el incidente: verificar si el dispositivo está realmente fuera del control del empleado (descartar que esté en otro puesto, en sala de reuniones, en mantenimiento, etc.).
- Identificar el tipo de dispositivo:
 - Ordenador portátil corporativo.
 - Teléfono móvil corporativo o BYOD con acceso a sistemas de la empresa.
 - Tableta corporativa o BYOD.
 - Pendrive o disco duro externo con información corporativa.
- Recopilar información básica del dispositivo:
 - Identificador del dispositivo (número de serie, IMEI, nombre de equipo, dirección MAC).
 - Usuario asignado y departamento.
 - Última ubicación conocida y circunstancias de la pérdida o robo.
 - Hora aproximada en que se detectó la ausencia.
- Determinar el estado de protección del dispositivo:
 - ¿Tenía cifrado de disco activado (BitLocker, FileVault, cifrado Android/iOS)?
 - ¿Tenía PIN, contraseña o biometría configurada?
 - ¿Estaba inscrito en MDM (Mobile Device Management)?
 - ¿Tenía acceso activo a correo, VPN, aplicaciones corporativas o almacenamiento en la nube?

2. Determinar qué información podía contener o acceder

- Revisar qué datos y sistemas eran accesibles desde el dispositivo:
 - Correo electrónico corporativo sincronizado localmente.
 - Documentos almacenados localmente (no en la nube).
 - Acceso a servicios internos mediante VPN o sesiones activas.
 - Credenciales guardadas en el navegador o en aplicaciones.
 - Datos de clientes, proveedores o empleados (PII).
 - Información financiera o contractual sensible.
- Verificar si el dispositivo tenía acceso a la página web corporativa, tienda online o servicios externalizados con credenciales almacenadas.

- Revisar si había sesiones activas en aplicaciones SaaS (correo, almacenamiento en la nube, CRM, ERP).
3. **Evaluar el riesgo real**
- Clasificar el riesgo según:
 - **Alto:** dispositivo sin cifrado, sin PIN, con credenciales almacenadas o datos sensibles locales.
 - **Medio:** dispositivo con PIN pero sin cifrado, o con acceso a sistemas corporativos.
 - **Bajo:** dispositivo cifrado, con PIN robusto, sin datos locales sensibles y con MDM activo.
 - Determinar si hay indicios de robo dirigido (en lugar de pérdida fortuita) que sugieran intención de acceder a la información.
 - Escalar a Dirección y Legal si el dispositivo contenía datos personales de clientes, empleados o proveedores.
4. **Evaluar el impacto y priorizar**
- Priorizar la respuesta según: tipo de datos expuestos, sistemas accesibles desde el dispositivo, número de personas afectadas y obligaciones regulatorias (RGPD).
 - Identificar si el dispositivo pertenecía a personal con acceso privilegiado (TIC, administración, dirección).

Remediar

Flujo de Respuesta – Pérdida o Robo de Dispositivo

Figure 9: Flujo de Respuesta – Pérdida o Robo de Dispositivo

- **Planificar eventos de remediación** en los que estos pasos se lancen juntos (o de forma coordinada), con los equipos apropiados listos para responder a cualquier interrupción.
- **Considere el momento y las compensaciones** de las acciones de remediación: su respuesta tiene consecuencias.

Contención **OBJETIVO:** Impedir el acceso a sistemas corporativos desde el dispositivo perdido o robado, revocar credenciales y sesiones activas, y borrar remotamente el dispositivo si es posible, sin destruir evidencia cuando sea relevante.

OBJETIVO: Especificar herramientas y procedimientos internos para cada paso (MDM, IAM, directorio activo, correo, VPN).

- **Bloquear el acceso del dispositivo a sistemas corporativos**
 - Revocar el certificado de VPN o desactivar el acceso VPN asociado al dispositivo o usuario.
 - Desactivar la cuenta de correo corporativo en el dispositivo (mediante MDM o desde el servidor de correo).

- Revocar tokens de sesión activos en aplicaciones SaaS y servicios en la nube.
- Bloquear el dispositivo de forma remota si el MDM lo permite.
- **Revocar y rotar credenciales**
 - Forzar el restablecimiento de contraseña de la cuenta corporativa del usuario afectado.
 - Revocar y regenerar claves API o tokens de acceso que pudieran estar almacenados en el dispositivo.
 - Si se sospecha reutilización de contraseñas: iniciar rotación en sistemas críticos relacionados.
 - Invalidar todas las sesiones activas del usuario en todos los sistemas.
- **Ejecutar borrado remoto (wipe) si procede**
 - Si el dispositivo está inscrito en MDM: ejecutar borrado remoto completo o borrado selectivo de datos corporativos.
 - Si es un dispositivo BYOD: ejecutar borrado selectivo limitado a datos y aplicaciones corporativas.
 - Documentar el momento y el resultado del borrado remoto.
 - Si el dispositivo no tiene MDM: coordinar con el fabricante o proveedor de la plataforma (Google, Apple) para bloqueo o borrado mediante cuenta corporativa asociada.
- **Denunciar ante las autoridades si hay indicios de robo**
 - Asesorar al empleado afectado para interponer denuncia ante las fuerzas de seguridad.
 - Documentar el número de denuncia para el expediente del incidente.
 - Proporcionar el IMEI u otros identificadores a las autoridades si lo solicitan.
- **Activar vigilancia reforzada**
 - Monitorizar accesos sospechosos a sistemas corporativos desde IPs o ubicaciones inusuales.
 - Activar alertas en SIEM para intentos de autenticación con las credenciales del usuario afectado.
 - Revisar logs de acceso a correo, VPN y aplicaciones durante las horas posteriores a la pérdida.

OBJETIVO: Considerar la automatización de medidas de contención mediante herramientas de orquestación (SOAR o MDM) donde exista.

Erradicar **OBJETIVO:** Eliminar cualquier vía de acceso residual que pudiera aprovecharse a través del dispositivo perdido o robado, y reforzar los controles para evitar que un dispositivo no gestionado pueda acceder a sistemas corporativos.

OBJETIVO: Especificar herramientas y procedimientos para cada paso (MDM, IAM, gestión de certificados).

- **Eliminar el dispositivo del inventario activo**
 - Dar de baja el dispositivo en el inventario de activos TIC.

- Eliminar el perfil del dispositivo en MDM una vez confirmado el borrado remoto.
 - Revocar certificados digitales asociados al dispositivo.
 - **Auditar accesos posteriores al incidente**
 - Revisar logs de autenticación desde el momento de la pérdida hasta la contención para detectar accesos no autorizados realizados desde el dispositivo.
 - Comprobar si se realizaron descargas, envíos de correo o accesos a datos sensibles en ese período.
 - Verificar que no se crearon reglas de reenvío de correo ni se modificaron permisos durante el período de exposición.
 - **Revisar y reforzar controles de acceso**
 - Asegurar que todos los dispositivos corporativos restantes tienen cifrado de disco activado.
 - Verificar que todos los dispositivos con acceso a sistemas corporativos están inscritos en MDM.
 - Aplicar política de acceso condicional: bloquear acceso a sistemas corporativos desde dispositivos no gestionados.
 - **Validación post-erradicación**
 - Confirmar que el dispositivo ya no aparece activo en ningún sistema de directorio, MDM o VPN.
 - Monitorizar durante al menos 72 horas posibles intentos de acceso con las credenciales del usuario afectado.
-

Comunicar

OBJETIVO: Comunicar con precisión, evitando especulación; coordinar con Legal, Dirección y, si aplica, autoridades y afectados. Cumplir con las obligaciones regulatorias del RGPD.

OBJETIVO: Especificar herramientas y procedimientos (incluyendo quién participa) o remitir al plan general.

Además de los pasos y orientaciones generales del plan de respuesta a incidentes:

1. Notificar a Dirección y al responsable de seguridad con resumen inicial: qué dispositivo se ha perdido o robado, cuándo, qué datos podrían haberse expuesto, y qué medidas de contención se han tomado.
2. Coordinar con Legal:
 - Evaluar obligaciones de notificación a la AEPD en un plazo máximo de 72 horas si el dispositivo contenía datos personales y no estaba cifrado (RGPD Art. 33).
 - Evaluar la obligación de notificación a los interesados (RGPD Art. 34) si el riesgo para sus derechos es alto (datos sensibles sin cifrar).
 - Revisar si aplica la póliza de ciberriesgo o seguro de equipos.

3. Notificar internamente a los departamentos afectados (TIC, RRHH si es un dispositivo de empleado, el departamento del usuario afectado).
 4. Si hay clientes o proveedores cuyos datos pudieran haber sido expuestos: preparar comunicado externo claro y verificable con instrucciones de actuación, coordinado con Legal y Dirección.
 5. Coordinar con RRHH si el incidente implica negligencia por parte del empleado (pérdida por descuido reiterado, incumplimiento de política de dispositivos): seguir el procedimiento disciplinario establecido.
-

Recuperación

OBJETIVO: Restablecer la operatividad del empleado afectado con un dispositivo seguro, reforzar los controles sobre dispositivos y mejorar la postura de seguridad para reducir la probabilidad de recurrencia.

OBJETIVO: Especificar herramientas y procedimientos para cada paso (MDM, inventario, formación, política de dispositivos).

Además de los pasos y orientaciones generales del plan de respuesta a incidentes:

1. Proporcionar al empleado un dispositivo sustituto correctamente configurado:
 - Cifrado de disco activado desde el inicio.
 - Inscrito en MDM antes de la entrega.
 - Credenciales nuevas y MFA habilitado.
 - Solo aplicaciones y accesos necesarios según su rol (mínimo privilegio).
2. Reforzar controles sobre dispositivos corporativos:
 - Verificar que todos los dispositivos en uso tienen cifrado, PIN y MDM activo.
 - Implementar política de borrado remoto automático tras un número determinado de intentos fallidos de desbloqueo.
 - Establecer inventario actualizado de dispositivos con acceso a sistemas corporativos.
3. Mejorar la visibilidad y detección:
 - Revisar cobertura de MDM: todo dispositivo con acceso a sistemas corporativos debe estar gestionado.
 - Implementar acceso condicional que bloquee dispositivos no inscritos en MDM.
 - Asegurar que los logs de acceso cubren todos los sistemas críticos accesibles desde dispositivos móviles.
4. Formación y concienciación:
 - Recordar a todos los empleados la política de uso y custodia de dispositivos corporativos.
 - Comunicar el procedimiento de notificación inmediata ante pérdida o robo.

- Reforzar la importancia del bloqueo automático de pantalla y el uso de contraseñas robustas.
5. Lecciones aprendidas:
 - Documentar la cronología completa, el tipo de dispositivo, los datos expuestos y las acciones realizadas.
 - Actualizar el registro de riesgos y la política de dispositivos móviles.
 - Revisar si la ausencia de MDM formalizado fue un factor agravante y planificar su implantación si no existe.

Referencia: Acciones del empleado ante la pérdida o robo de un dispositivo corporativo

OBJETIVO: Personalizar los pasos para empleados que detecten la pérdida o robo de un dispositivo con acceso a sistemas de la empresa.

1. Mantenga la calma. No espere a ver si aparece: notifique de inmediato al responsable de TIC o al servicio de soporte.
2. Tome nota de: cuándo fue la última vez que tuvo el dispositivo, dónde estaba, y si cree que fue pérdida o robo.
3. Si sospecha robo, interponga denuncia ante la Policía o Guardia Civil y comunique el número de denuncia al equipo de TIC.
4. No intente acceder remotamente al dispositivo por su cuenta ni instalar aplicaciones de rastreo no autorizadas.
5. No comparta sus credenciales corporativas con nadie mientras el incidente esté activo.
6. Colabore con el equipo de TIC facilitando toda la información necesaria (número de serie, IMEI, últimas aplicaciones usadas, etc.).
7. Tenga paciencia: pueden aplicarse restricciones temporales a su cuenta mientras se resuelve el incidente. **Gracias por avisar de inmediato.**

Referencia: Acciones del servicio de asistencia técnica ante la notificación de pérdida o robo de dispositivo

OBJETIVO: Personalizar los pasos para el personal del helpdesk ante la notificación de pérdida o robo de un dispositivo corporativo.

1. Mantenga la calma y abra un ticket documentando el incidente con la mayor cantidad de información posible.
2. Recopile del empleado afectado:
 - ¿Qué dispositivo es (tipo, marca, modelo, número de serie o IMEI)?
 - ¿Cuándo fue la última vez que lo tuvo y dónde?
 - ¿Fue pérdida o hay indicios de robo?
 - ¿Tenía PIN, contraseña o cifrado activado?

- ¿Qué aplicaciones y datos corporativos tenía accesibles?
3. Verifique en el inventario si el dispositivo está inscrito en MDM y qué datos y accesos tenía configurados.
 4. No restablezca contraseñas ni ejecute el borrado remoto sin coordinación con el responsable de seguridad o TIC.
 5. Escale de inmediato al equipo de seguridad o al responsable de TIC con toda la información recopilada.
 6. Siga las instrucciones del equipo de seguridad para las acciones de contención (bloqueo remoto, revocación de accesos, borrado).

Recursos

Información adicional

1. MITRE ATT&CK: Initial Access – Lost and Stolen Devices (T1078)
2. NIST SP 800-124r2: Guidelines for Managing the Security of Mobile Devices in the Enterprise
3. NIST SP 800-61r2: Computer Security Incident Handling Guide
4. AEPD: Guía para la notificación de brechas de datos personales
5. RGPD Art. 33 – Notificación de una violación de la seguridad de los datos personales a la autoridad de control
6. INCIBE: Robo o pérdida de dispositivos móviles en la empresa
7. CCN-CERT: Guía CCN-STIC – Seguridad en dispositivos móviles
8. ENISA: Smartphone Secure Development Guidelines
9. CIS Controls – Control 12: Network Infrastructure Management (gestión de dispositivos)
10. Apple: Find My – Gestión remota de dispositivos iOS/macOS# Roles

A continuación se presentan las descripciones, los deberes y la formación para cada uno de los roles definidos en la respuesta a un incidente.

TODO: Personalizar los roles, las descripciones, las funciones y la formación, si es necesario.

Estructura de los roles

- Equipo de Mando
 - Incident Commander
 - Incident Commander-Adjunto
 - Escriba
- Equipo de enlace
 - Enlace Interno Enlace
 - Enlace externo
- Equipo de Operaciones
 - Expertos en la materia (SMEs) para Sistemas
 - SMEs para equipos/unidades de negocio

- SMEs para las funciones ejecutivas (*p.ej.*, Legal, RRHH, Finanzas) En el caso de incidentes complejos de mayor envergadura, la estructura de funciones puede ajustarse para tener en cuenta la creación de subequipos. Para más información, lea cómo gestionamos los Incidentes Complejos.

Esta es una **estructura flexible**: cada rol no será ocupado por una persona diferente para cada incidente. Por ejemplo, en un incidente pequeño, el adjunto podría actuar como escribiente y enlace interno. La estructura es flexible y se adapta al incidente.

Tiempos de Guerra vs. Tiempos de Paz

En las llamadas de respuesta a Incidentes (“tiempos de guerra”), una estructura organizativa diferente anula las operaciones normales (“tiempos de paz”):

- El Comandante del incidente está al mando. Independientemente de su rango en tiempos de paz, ahora es la persona de mayor rango en la llamada, superior al director general o CEO.
- Los primeros intervinientes (las personas que actúan como primeros intervinientes de un equipo/servicio) son las personas de mayor rango de ese servicio.
- Las decisiones serán tomadas por el IC tras considerar la información presentada. Una vez tomada la decisión, es definitiva.
- El IC puede tomar decisiones más arriesgadas que las que normalmente se considerarían en tiempos de paz.
- El IC puede ir en contra de una decisión consensuada. Si se hace una encuesta, y 9/10 personas están de acuerdo pero 1 está en desacuerdo. El IC puede elegir la opción del desacuerdo a pesar del voto de la mayoría. Aunque no esté de acuerdo, la decisión del IC es definitiva. Durante la convocatoria no es el momento de discutir con ellos.
- El IC puede utilizar un lenguaje o comportarse de una manera que usted considere grosera. Esto es tiempo de guerra, y necesitan hacer lo que sea necesario para resolver la situación, por lo que a veces se producen groserías. Esto no es personal, y es algo que debes estar preparado para experimentar si nunca has estado en una situación de guerra.
- Es posible que el IC te pida que abandones la llamada, o incluso que te eche a la fuerza de una llamada. Esto queda a discreción del IC si considera que no estás aportando nada útil. De nuevo, esto no es personal y debes recordar que los tiempos de guerra son diferentes a los tiempos de paz.

Roles: Todos los participantes

Descripción

Todos los participantes en la respuesta a un incidente tienen la responsabilidad de ayudar a resolver el incidente de acuerdo con el plan de respuesta a incidentes,

bajo la autoridad del Incident Commander.

Deberes

Exhibir la etiqueta de la llamada

- Participar tanto en la llamada como en el chat.
- Mantener el ruido de fondo al mínimo.
- Mantener el micrófono silenciado hasta que tenga algo que decir.
- Identificarse cuando entre en la llamada; diga su nombre y su función (por ejemplo, “Soy el SME del equipo x”).
- Hablar con claridad.
- Ser directo y objetivo.
- Mantener las conversaciones/debates breves y al grano.
- Comunicar cualquier preocupación al Incident Commander (IC) en la llamada.
- Respetar las limitaciones de tiempo dadas por el Incident Commander.
- Si te unes a un solo canal (llamada o chat), no participar activamente, ya que provoca una comunicación inconexa.
- **Utilizar una terminología clara y evitar usar acrónimos o abreviaturas. La claridad y la precisión son más importantes que la brevedad.**

Referencia: Procedimiento común de voz El [procedimiento de voz] estándar de la radio (https://en.wikipedia.org/wiki/Voice_procedure#Words_in_voice_procedure) **no es obligatorio**, sin embargo, es posible que escuche ciertos términos (o que tenga que utilizarlos usted mismo). Las frases comunes incluyen:

- **Ack/Rog:** “He recibido y entendido”
- **Say Again:** “Repita su último mensaje”
- **Standby:** “Por favor, espere un momento para la siguiente respuesta”
- **Wilco:** “Cumpliré”

No invente nuevas abreviaturas; favorezca ser explícito sobre lo implícito.

Seguir al Incident Commander El Incident Commander (IC) es el líder del proceso de respuesta al incidente.

- Siga las instrucciones del Incident Commander.
- No realice ninguna acción a menos que el Incident Commander se lo indique.
- El jefe normalmente sondeará si hay objeciones fuertes antes de asignar una acción importante. Plantee sus objeciones si las tiene.
- Una vez que el jefe haya tomado una decisión, sígala (incluso si no está de acuerdo).
- Responde a cualquier pregunta que te haga el jefe de forma clara y concisa. Responder “no sé” es aceptable. No adivine.

- El jefe puede pedirte que investigues algo y que le contestes en X minutos. Esté preparado con una respuesta dentro de ese tiempo. Pedir más tiempo es aceptable, pero proporcione al jefe una estimación.

Capacitación

Lee y entiende el plan de respuesta a incidentes, incluyendo los roles y los libros de jugadas. ## Rol: Incident Commander

Descripción

El Incident Commander(IC) actúa como la única fuente de lo que realmente está ocurriendo y va a ocurrir durante un incidente grave. El IC es el individuo con mayor rango en cualquier llamada de incidente, sin importar el rango en el día a día. Ellos son los que toman decisiones durante un incidente; delegan tareas y prestan atención a expertos en la materia que están tratando para resolver el incidente. Las decisiones tomadas por el Incident commander las decisivas.

Tu trabajo como Incident commander evaluar la situación, proveer un guiado claro y coordinado, contratar otros trabajadores para recolectar contexto/detalles.**No realizar investigaciones o remedios**, delega estos trabajos.

Deberes

Resuelve el incidente lo más rápido y seguro posible usando el plan de respuesta de incidentes como plantilla de trabajo: guía al equipo de investigación, remedio, comunicación. Utiliza al adjunto para que te ayude, y delegue a relevantes enlaces y expertos a tu discreción.

1. Ayuda a prepararnos para los incidentes,
 - Establecer canales de comunicación para incidentes.
 - Redirige a las personas hacia estos canales de comunicación cuando ocurra algún incidente grave.
 - Entrena a miembros del equipo sobre como comunicarte durante incidentes y entrena a otros Incident Commanders.
2. Dirige los incidentes hacia una solución,
 - Lleva a todos al mismo canal de comunicación.
 - Recolecta información de los miembros del equipo por sus servicios de estatus.
 - Recolecta propuestas de reparación de acciones, después recomienda acciones de reparación para que se lleven a cabo.
 - Delega todas las acciones de reparación, el Incident Commander no es un resolutor.
 - Es la única fuente de autoridad en el estado del sistema.
3. Facilita las llamadas y reuniones,
 - Gana consenso (Realiza encuestas durante las llamadas)
 - Proporciona actualizaciones de estatus
 - Reduce el alcance (despedir a los asistentes cuando sea posible)

- Spin off sub-equipos
 - Transfiere el control cuando sea necesario
 - Firmar las llamadas
 - Mantener el orden
 - Obtén respuestas directas
 - Manejar las caídas de ejecutivos como
 - Anular al Incident Commander
 - Desmotivación
 - Petición de información
 - Cuestionar la severidad
 - Manejar respuestas perturbadoras o beligerantes
4. Post Mortem,
- Crear la plantilla inicial justo después del incidente para que las personas puedan escribir sus opiniones mientras están frescas.
 - Asignar el post-mortem después de que el evento termine, esto puede darse después de terminar la llamada.
 - Trabaja con los gerentes o jefes de equipo para organizar acciones preventivas.

El Incident Commander utiliza métodos y lenguajes adicionales:

- Siempre anuncie cuando se una a la llamada si es el IC de guardia.
- **No** permita que las discusiones se salgan de control. Mantenga las conversaciones cortas.
- Tenga en cuenta las objeciones de los demás, pero tu decisión es la definitiva.
- Si alguien está interrumpiendo activamente tu decisión, expúlsalo.
- Anuncia el final de la llamada.
- Después de un incidente, comuníquese con otros Incident Commander sobre cualquier acción que considere necesaria.

Utilice una terminología clara y evite las siglas o abreviaturas. La claridad y la precisión son más importantes que la brevedad.

Prácticas

- Lea el plan de respuesta a incidentes, incluidos todos los roles y manuales.
- Participar en un ejercicio de respuesta a incidentes.
- Seguir a un Incident Commander actual sin participar activamente, manteniendo sus preguntas hasta el final.
- Tomar la iniciativa de un Incident Commander. Responda a incidentes con el IC actual allí para hacerse cargo si es necesario.
- *OPCIONAL*: facilitar las prácticas
- *OPCIONAL*: recurre a Incident Responders as Facilitators (and Therapists) y al PagerDuty Incident Commander training para más ideas y discusiones.

pre-requisitos No hay requisitos previos de antigüedad o unidad de negocios para convertirse en Incident Commander, es un rol abierto a cualquier persona con

la capacitación y la capacidad. Antes de que pueda ser un Incident Commander, se espera que cumpla con los siguientes criterios:

- Excelentes **habilidades de comunicación** verbal y escrita.
- **Conocimiento de alto nivel** de la infraestructura y las funciones comerciales.
- Excelente pensamiento crítico, juicio y toma de decisiones.
- Flexibilidad y capacidad para **escuchar comentarios de expertos**, modificando los planes según sea necesario.
- **Participó en al menos dos respuestas a incidentes.**
- Capacidad para **tomar el mando y disposición para expulsar a las personas de una llamada** para eliminar las distracciones, incluso si se trata del director ejecutivo.

¡No se requieren conocimientos técnicos profundos! Los Incident Commander no requieren un conocimiento técnico profundo de nuestros sistemas. Su trabajo como Incident Commander es coordinar la respuesta, no realizar cambios técnicos. No crea que no puede ser un Incident Commander solo porque no está en el departamento de ingeniería.

Graduación Al finalizar el entrenamiento, agréguese a la lista de Incident Commander.

Rol: adjunto del Incident Commander (adjunto)

Descripción

Un adjunto del Incident Commander (adjunto) es un papel de apoyo directo al Incident Commander (IC). El adjunto permite que el IC se centre en el problema que tiene entre manos, en lugar de preocuparse por documentar los pasos o controlar los tiempos. El adjunto apoya al IC y lo mantiene centrado en el incidente. Como adjunto, se espera que asuma el mando del IC si éste lo solicita.

Funciones

1. Plantear al Incident Commander cuestiones que, de otro modo, no se abordarían (vigilar los temporizadores que se han puesto en marcha, retomar los elementos que se han perdido de una lista, etc.).
1. Ser un Incident Commander “de reserva”, en caso de que el jefe principal tenga que hacer la transición a un SME, o tenga que alejarse de la función de IC.
1. Gestionar la llamada del incidente y estar preparado para retirar a las personas de la llamada si así lo indica el Incident Commander.
- Supervisar el estado del incidente y notificar al IC si el nivel de gravedad del incidente aumenta.
- Supervise los temporizadores:
 - controlar el tiempo que ha durado el incidente

- Notificar al IC cada X minutos para que pueda tomar medidas (por ejemplo, “IC, el incidente está ahora en la marca de 10 minutos”).
6. Supervisar los plazos de las tareas (*p.ej.*, “IC, avisa de que el temporizador de la investigación de [TEAM] se ha agotado”).

Formación

- Leer y comprender el plan de respuesta a incidentes, incluyendo los roles y los libros de jugadas.

Requisitos previos

- Estar entrenado como Incident Commander.

Traducción realizada con la versión gratuita del traductor www.DeepL.com/Translator

Rol: Escriba

Descripción

Un escriba documenta la línea de tiempo de un incidente a medida que avanza, y se asegura de que todas las decisiones y datos importantes se capturen para su posterior revisión. El escriba debe centrarse en el archivo del incidente, así como en los elementos de seguimiento para una acción posterior.

Funciones

1. Asegurarse de que la llamada del incidente se está grabando.
2. 2. Anotar en el chat y en la línea de tiempo del expediente: los datos, eventos y acciones importantes, a medida que se producen. Específicamente:
 - Acciones clave a medida que se llevan a cabo
 - Informes de estado cuando el IC los proporcione
 - Cualquier llamada clave durante la llamada o en la revisión final
3. Actualice el chat indicando quién es el IC, quién es el adjunto y que usted es el escribiente (si no lo ha hecho ya).

Escribir es más un arte que una ciencia. El objetivo es mantener un registro preciso de los eventos importantes que ocurrieron, Usa tu juicio y experiencia. Pero aquí hay algunas cosas generales que definitivamente querrás capturar como escribiente.

- El resultado de cualquier decisión de la votación. ### Cualquier elemento de seguimiento que se llame “Deberíamos hacer esto..”, “¿Por qué no se hizo esto?”, etc.

Formación

Lea y comprenda el plan de respuesta a incidentes, incluyendo los roles y los libros de jugadas.

Requisitos previos

- Excelentes habilidades de **comunicación verbal y escrita**.
- Cualquiera puede actuar como escribiente durante un incidente, y son elegidos por el Incident Commander al inicio de la llamada.
- Normalmente, el ayudante actuará como escribiente.

Proceso de formación

- Lea el plan de respuesta a incidentes, incluyendo todos los roles y libros de jugadas.
- *OPCIONAL*: Paralizar las acciones de un escriba durante un incidente o ejercicio, y buscar la opinión del escriba real y del Incident Commander.

Rol: Experto en la materia {Subject Matter Expert (SME)}

Descripción

Un experto en la materia (SME) es un experto en el dominio o responsable designado de un equipo, componente o servicio (un “área”). Está ahí para apoyar al Incident Commander en la identificación de la causa del incidente, sugiriendo y evaluando las acciones de investigación, remediación y comunicación, y realizando el seguimiento de las mismas según se le encomiende.

Funciones

1. Diagnosticar problemas comunes dentro de su área de experiencia.
2. Solucionar rápidamente los problemas detectados durante un incidente.
3. Comunicación concisa:
 - Estado: ¿Cuál es el estado actual de su área? ¿Está buen estado o no?
 - Acciones: ¿Qué medidas hay que tomar si su zona no se encuentra en un buen estado?
 - Necesidades: ¿Qué apoyo necesita para realizar una acción?
4. Participar en las fases de investigación, remediación y/o comunicación de la respuesta.
5. Anunciar todas las sugerencias al comandante del incidente, es su decisión cómo proceder, no siga ninguna acción a menos que se le indique.

Si está de guardia para cualquier equipo, puede ser llamado para un incidente y se espera que responda como experto en la materia (SME) para su equipo, componente o servicio. Cualquiera que se considere un “experto en la materia”

puede actuar como SME para un incidente. Por lo general, el principal de guardia del equipo actuará como SME para ese equipo.

Prepárese para el periodo de guardia

1. Esté preparado, habiéndose familiarizado ya con nuestras políticas y procedimientos de respuesta a incidentes.
2. Asegúrese de que ha configurado sus métodos de alerta de acuerdo con nuestro procedimiento de guardia.
3. Compruebe que puede unirse a la llamada de incidentes. Es posible que tenga que instalar un plugin para el navegador.
4. Tenga en cuenta su próxima vez de guardia y organice los cambios en función de los viajes, las vacaciones, las citas, etc.
5. Si usted es el Incident Commander, asegúrese de no estar de guardia con su equipo al mismo tiempo que está de guardia como Incident Commander.

Durante el periodo de guardia

1. Tenga su ordenador portátil e Internet con usted en todo momento durante su período de guardia (oficina, casa, un MiFi, un teléfono con un plan de conexión, etc).
2. Si tiene citas importantes, debe conseguir que otra persona de su equipo cubra esa franja horaria con antelación.
3. Cuando recibas una alerta de incidente, se espera que te unas a la llamada de incidente y chatees lo antes posible (en cuestión de minutos).
4. El Incident Commander le hará preguntas o le dará acciones. Responde a las preguntas de forma concisa y sigue todas las acciones que se te den (incluso si no estás de acuerdo con ellas).
5. Si no estás seguro de algo, haz venir a otros miembros de tu equipo que puedan ayudarte. **Nunca dudes en escalar**, si es necesario.
6. No culpes. Este proceso de respuesta a incidentes no tiene ninguna culpa: culpar es contraproducente y distrae del problema en cuestión. La revisión posterior a la acción identificará los puntos en los que todos podemos mejorar.

Formación

- Lea y comprenda el plan de respuesta a incidentes, incluidas las funciones y las guías de actuación.

Rol: Enlace

Descripción

Los enlaces interactúan con otros equipos o partes interesadas fuera del equipo de respuesta a incidentes. A menudo incluyen:

- Enlace externo: responsable de interactuar con clientes, ya sea directamente o por vía pública.
- Enlace interno: responsable de interactuar con las partes interesadas internas. Tanto si se trata de notificar un incidente al equipo interno como al movilizar respuestas adicionales dentro de la organización.

Deberes

Enlace con el exterior o con el cliente

1. Subir cualquier mensaje de cara al público con respecto al incidente (Twitter, etc).
2. Notificar al IC de cualquier cliente o medios de comunicación que informen de los efectos del incidente.
3. Proporcionar a los clientes el mensaje externo del post-mortem una vez que se haya completado.
4. Contactar o interactuar con las partes interesadas externas, como proveedores, socios, fuerzas de seguridad, *etc.*
5. **No** sentirse responsable de la creación de cada mensaje: trabajar con el Incident Commander y otras partes interesadas.
6. Según proceda, mantener a los clientes informados durante un incidente.
7. Actuar como voz de nuestros clientes ante el Incident Commander, ya que esto es útil para la toma de decisiones del IC.
8. Obtener la aprobación del mensaje después de haber elaborado el mensaje público: copiar el mensaje en el chat y esperar la confirmación verbal/escrita del IC antes de continuar.

Pistas para mensajes públicos

- Preparar de antemano un mensaje por defecto que pueda utilizarse para la actualización inicial si se desconoce el alcance del problema.
- Sé honesto. No mientas o supongas.
- Describe nuestros progresos en la resolución del incidente.
 - “Somos conscientes de un incidente. . . ”
 - “Estamos investigando los retrasos en las notificaciones. . . ”
 - “Se ha aplicado una corrección y se está desplegando actualmente. . . ”
 - “El problema ha sido resuelto. . . ”
- Explique claramente cómo afecta el incidente a los clientes. Esta es la principal información que les interesa a los clientes.
- Proporcionar soluciones que los clientes puedan utilizar hasta que se resuelva la incidencia.
- No calcule los tiempos de resolución.
- Proporcionar el nivel de detalle adecuado.

Enlace interno

1. Página de SMEs u otro personal de guardia según las instrucciones del Incident Commander.
2. Notificar o movilizar a otros equipos de la organización (por ejemplo, Finanzas, Legal, Marketing), según las instrucciones del Incident Commander.
3. Seguir y anticiparse a los SMEs en la convocatoria.
4. Interactuar con las partes interesadas y proporcionar actualizaciones de estado cuando sea necesario.
5. Interactuar con las partes interesadas internas para responder a sus preguntas, para mantener la llamada principal libre de distracciones.
6. Proporcionar actualizaciones periódicas de la situación al equipo ejecutivo, ofreciendo un resumen ejecutivo de la situación actual.

Formación

Leer y comprender el plan de respuesta a incidentes, incluyendo los roles y las guías.

Prerequisitos

- Excelentes **habilidades de comunicación** verbal y escrita.
- *OPCIONAL*: Formación en atención al cliente.
- *OPCIONAL*: Comunicación corporativa o formación en marketing.

Realizar una revisión posterior a la acción (Conduct an After Action Review, AAR)

1. Programe una reunión de revisión posterior a la acción (AAR) dentro de 5 días laborables e invite a los asistentes que figuran en Incident Commander; Seguridad; IT Ops; Propietarios de servicio; Legal; DPO/Compliance; Comunicación. Incluya siempre a los siguientes:
 - El Incident Commander.
 - Los propietarios de los servicios implicados en el incidente.
 - Ingeniero(s)/responsable(s) clave(s) implicado(s) en el incidente.
2. Designe a un propietario del AAR que investigue el incidente antes de la reunión para prepararlo, estudiando el proceso del incidente en sí, incluyendo la revisión de notas e informes.

Realización de la reunión AAR

Documente las respuestas a las siguientes preguntas clave:

1. **¿Qué ocurrió?** Cree una línea de tiempo, apoyada con datos u otros artefactos. **Evitar las culpas. Busca los hechos.**
2. **¿Qué se suponía que iba a ocurrir?**
 - Detallar las desviaciones del proceso, el procedimiento o las mejores prácticas, incluidas las evaluaciones de los SME.

- Identifique las formas en que el incidente podría haberse detectado antes o haberse respondido con mayor eficacia.
3. **¿Cuáles fueron las causas fundamentales?** Encuentre la raíz de lo que ocurrió y de lo que debería haber ocurrido.
 4. **¿Cómo podemos mejorar?** Capture los elementos de acción con asignados y fechas de vencimiento. Considerar:
 - Detener: ¿Qué debemos dejar de hacer?
 - Empezar: ¿Qué deberíamos empezar a hacer?
 - Continuar: ¿Qué debemos seguir haciendo?

Comunicar el estado y los resultados del AAR

El propietario del informe, en coordinación con el enlace interno, comunicará el estado del informe (véase más abajo).

Descripciones de estado

Estado	Descripción
Borrador	La investigación de la AAR sigue en curso
En revisión	La investigación AAR se ha completado, y está lista para ser revisada durante la reunión AAR.
Revisado	La reunión de AAR ha terminado y el contenido ha sido revisado y acordado. Si hay “Mensajes externos” adicionales, el equipo de comunicación tomará medidas para prepararlos.
Cerrado	No es necesario realizar más acciones en el AAR (los problemas pendientes se rastrean en los tickets). Si no hay “Mensajes Externos”, pase directamente a esto una vez que la reunión haya terminado. Si hay “Mensajes Externos” adicionales, el equipo de comunicaciones actualizará el AAR Cerrado una vez enviado.

Comunicar internamente los resultados del AAR y finalizar la documentación del AAR.

Acerca de

Esta plantilla ha sido creada por el equipo de Counteractive Security, para ayudar a todas las organizaciones a comenzar de forma concisa, directa, específica, flexible y gratuita un plan de respuesta de incidentes. crea un plan que utilizaras para responder de manera eficiente, minimizando los costes e impactos, para volver a trabajar lo mas rapido posible.

Licencia

Esta plantilla esta proporcionado bajo la licencia de apache, version 2.0. puedes ver el codigo fuente en <https://github.com/counteractive>.

Instrucciones

Personaliza esta plantilla para tu organizacion. Las instrucciones estan disponibles en el README del proyecto. Para asistencia profesional con respuestas de incidentes, o con customizacion, implementacion, o testeo de tu plan, porfavor contacta con nosotros por email o telefono.

Referencias y material adicional

- NIST Computer Security Incident Handling Guide (NIST)
- CERT Societe Generale Incident Response Methodologies
- NIST Cybersecurity Framework
- Incident Handler's Handbook (SANS)
- Responding to IT Security Incidents (Microsoft)
- Defining Incident Management Processes for CSIRTs: A Work in Progress (CMU)
- Creating and Managing Computer Security Incident Handling Teams (CSIRTs) (CERT)
- Incident Management for Operations (Rob Schnepp, Ron Vidal, Chris Hawley)
- *Incident Response & Computer Forensics, Third Edition* (Jason Luttgens. Matthew Pepe. Kevin Mandia)
- *Incident Response* (Kenneth R. van Wyk, Richard Forno)
- The Checklist Manifesto (Atul Gawande)
- The Field Guide to Understanding Human Error (Sidney Dekker)
- Normal Accidents: Living with High-Risk Technologies (Charles Perrow)
- Site Reliability Engineering (Google)
- Debriefing Facilitation Guide (Etsy)
- Every Minute Counts: Leading Heroku's Incident Response (Blake Gentry)
- Three Analytical Traps in Accident Investigation (Dr. Johan Bergström)
- US National Incident Management System (NIMS) (FEMA)
- Informed's NIMS Incident Command System Field Guide (Michael J. Ward)
- Advanced PostMortem Fu and Human Error 101 (Velocity 2011)
- Blame. Language. Sharing.